



UPPSALA
UNIVERSITET

UPTEC IT XXXXX

Degree project 30 credits

May , 2026

An Information Security Vendor Assessment Framework for AI Procurement

Lukas Bängs
Michel Messo

Master's Programme in Computer and Information
Engineering



UPPSALA
UNIVERSITET

An Information Security Vendor Assessment Framework for AI Procurement

Lukas Bångs
Michel Messo

Abstract

The accelerated adoption of AI-powered products and services is transforming how organisations should procure and integrate external software. Unlike conventional software, AI products may process data through opaque inference pipelines, rely on third-party foundation models, and change behaviour through silent model updates. While standards like ISO/IEC 27001 require organisations to assess supplier risks, its controls are technology-neutral and do not guide the assessor toward AI-specific risk areas. Existing AI governance standards and industry guides describe relevant risks but do not provide structured assessment criteria that information security professionals can apply within their existing supplier evaluation process.

We present a vendor assessment framework that enables information security professionals to assess AI products within an ISO 27001-aligned supplier assessment process. The framework classifies AI products along two axes, operational autonomy and data sensitivity, to determine whether a baseline or deeper diligence assessment is required. It defines 18 baseline and 13 deeper diligence assessment questions, each mapped to the CIA triad and supplemented with evaluation guidance designed for assessors without AI-specific expertise. The framework was developed using the Design Science Research method and evaluated through illustrative scenarios applying it to two real AI products with different risk profiles. Our evaluation shows that the classification mechanism produces meaningfully different assessment processes for products at different autonomy levels, and that the assessment questions surface crucial AI-specific risks.

Faculty of Science and Technology

Uppsala University, Place of publication Uppsala

Supervisor: Hedvig Lindberg Subject reader: Jingwei Dong

Examiner: Anders Arweström Jansson

Sammanfattning

Den snabba utvecklingen inom AI och tillhörande produkter och tjänster förändrar hur organisationer bör granska och integrera denna typ av mjukvara. Till skillnad från traditionella system kan AI-produkter bearbeta data genom otydliga flöden, vara beroende av tredjepartsmodeller och ändra beteende genom osynliga modelluppdateringar. Å ena sidan kräver standarder som ISO/IEC 27001 att organisationer utvärderar sina leverantörsrisker, men dess kontroller är teknikagnostiska och vägleder inte granskaren mot AI-specifika riskområden. Befintliga ramverk för AI-styrning och branschstandarder täcker å andra sidan relevanta risker, men tillhandahåller inga strukturerade bedömningskriterier som informationssäkerhetsspecialister kan tillämpa inom sin nuvarande process för leverantörsgranskningar.

Vi presenterar ett ramverk för leverantörsgranskningar som gör det möjligt för informationssäkerhetsspecialister att utvärdera AI-produkter inom en process som är i linje med ISO 27001. Ramverket klassificerar AI-produkter utifrån två axlar, operativ autonomi och datakänslighet, för att fastställa huruvida en grundläggande bedömning (baseline) eller en fördjupad granskning (deeper diligence) krävs. Ramverket definierar 18 grundläggande och 13 fördjupade bedömningsfrågor, där varje fråga är kartlagd mot CIA-triaden och kompletteras med vägledning utformad för granskare utan specifik AI-expertis. Ramverket har utvecklats enligt Design Science Research metodiken och utvärderats genom illustrativa scenarier där det tillämpats på två verkliga AI-produkter med olika riskprofiler. Vår utvärdering visar att klassificeringsmekanismen resulterar i rimligt anpassade bedömningsprocesser för produkter med olika nivåer av autonomi, samt att bedömningsfrågorna framgångsrikt tar upp kritiska AI-specifika risker.

Contents

Acronyms	vi
1 Introduction	1
1.1 Problem Description	2
1.2 Research Questions	3
1.3 Thesis Outline	3
2 Background	4
2.1 Information Security and Classification	4
2.2 ISO/IEC 27001	5
2.3 AI Systems	7
2.3.1 The need for AI system classification	7
2.4 Information Security Risks of AI Systems	8
2.4.1 Confidentiality	9
2.4.2 Integrity	10
2.4.3 Availability	11
2.5 Related Work	11
2.5.1 Existing AI Vendor Assessment Frameworks	12
2.5.2 Comparison	13
3 Method	15
3.1 Design Science Research	15
3.2 Application of DSRM	16
3.2.1 Step 1 - Problem identification.	16
3.2.2 Step 2 - Design objectives.	17

3.2.3	Step 3 - Design and development.	18
3.2.4	Step 4 - Demonstration.	20
3.2.5	Step 5 – Evaluation.	21
3.2.6	Step 6 - Communication.	21
4	Results - The Framework	22
4.1	Scope	22
4.2	Classification	23
4.2.1	Data Sensitivity	23
4.2.2	Operational Autonomy	24
4.3	Assessment Questions	25
4.3.1	Baseline	26
4.3.2	Deeper Diligence	27
4.4	Assessment Process	27
5	Evaluation - Illustrative Scenario	29
5.1	Illustrative Scenario A: Miro	29
5.1.1	Context	29
5.1.2	Confidentiality	30
5.1.3	Integrity	30
5.1.4	Availability	31
5.2	Illustrative Scenario B: Claude CoWork	31
5.2.1	Context	31
5.2.2	Confidentiality	32
5.2.3	Integrity	33
5.2.4	Availability	34

5.3	Evaluation Against Design Objectives	34
5.4	Limitations of the Scenario-Based Evaluation	35
6	Discussion	36
6.1	Research questions	36
6.1.1	Research Question 1	36
6.1.2	Research Question 2	37
6.2	Limitations	38
6.3	Ethical and societal aspects	39
7	Conclusions	40
7.1	Future Work	40
A	Assessment Framework Questionnaires	47
B	Miro - Baseline Assessment	58
C	Claude CoWork - Deeper Diligence Assessment	64

Acronyms

AI Artificial Intelligence. 3, 5, 7–12

API Application Programming Interface. 1, 7, 8, 11

CIA Confidentiality, Integrity, and Availability. 4, 9, 36

CISO Chief Information Security Officer. 22

DSR Design Science Research. 15, 21

HITL Human-In-The-Loop. 20, 32–34, 37, 41

ICT Information and Communication Technology. 6, 11

ISMS Information Security Management System. 4, 5, 22, 23

LLM Large Language Model. 7, 10, 22, 33, 38

SaaS Software-as-a-Service. 7, 9, 29

VAF Vendor Assessment Framework. 12, 13

1 Introduction

Artificial intelligence has, in a remarkably short time, moved from a largely experimental technology to a routine component of organisational operations. Since the public release of ChatGPT in late 2022, both awareness and adoption of AI have accelerated across sectors. According to the 2026 AI Index from Stanford, 88% of surveyed organisations used AI in 2025, and 70% used generative AI in at least one business function [51]. As a result, organisations increasingly depend not only on their own internally developed systems, but also on external AI models, Application Programming Interface (API)s, platforms, and other upstream suppliers.

This development creates a practical challenge for organisations that take information security seriously. When an organisation procures an AI service, or builds an internal solution on top of externally provided AI components, it also inherits risks connected to that supplier. These risks are not limited to traditional concerns such as availability, confidentiality, and contractual compliance. AI products may also involve opaque model behaviour, uncertain training data provenance, sensitive data exposure, changing model performance, and limited transparency from vendors. NIST's Generative AI Profile highlights that generative AI introduces risks related to information security and privacy, and recommends that organisations update procurement due diligence accordingly [42]. In other words, AI products cannot simply be treated as ordinary software in procurement and supplier assessment.

The problem is further complicated by the fact that many advanced AI products are difficult to evaluate from the outside. The 2026 AI Index notes that the most capable AI models are increasingly among the least transparent [51]. For an adopting organisation, this creates an asymmetry: the organisation remains responsible for managing supplier-related risk, while the information needed to assess that risk may be incomplete, difficult to interpret, or unavailable. This makes AI procurement not only a technical or legal matter, but also a concrete information security governance problem.

For organisations working under ISO/IEC 27001, this challenge becomes especially concrete. ISO 27001 requires organisations to manage supplier-related information security risks through controls A.5.19–A.5.22. These controls require a structured approach to supplier relationships, contractual security requirements, supply chain security, and the monitoring of supplier services. However, they are intentionally technology-neutral. This is an advantage for a general-purpose standard, but it also means that the standard does not specify what an assessor should look for when the product under review is an AI system. For conventional software and IT services, the relevant assessment areas are relatively well established in practice. For AI products, they are not. As a result, information security professionals may be responsible for evaluating AI suppliers

without having practical AI-specific criteria to support that evaluation.

At the same time, AI-specific governance frameworks are still developing. ISO/IEC 42001, published in 2023, addresses AI management systems at the organisational level [24], and the EU AI Act introduces a risk-based regulatory approach to AI systems [13]. These developments are important, but they do not directly solve the day-to-day problem faced by an information security professional who must assess a particular AI product during procurement. They provide governance principles, management requirements, and legal obligations, but not a concrete assessment method that can be integrated into an existing ISO 27001 supplier review process. In practice, this leaves a gap between high-level AI governance and operational security assessment.

This thesis addresses that gap by developing a vendor assessment framework for AI products, designed to function as a practical extension of the ISO 27001 supplier assessment process. Rather than replacing existing supplier assessment routines, the framework builds on them and adapts them to the specific characteristics of AI products. The framework is intended for information security professionals who already manage supplier assessments, but who may not have any expertise in AI. Its purpose is therefore not only to identify AI-specific information security risks, but also to make those risks assessable in a structured and proportionate way.

More specifically, the framework classifies AI products according to risk-relevant properties, uses that classification to select assessment questions proportionally, and provides guidance for how the answers should be interpreted. In this way, the framework aims to support consistent and practical assessments across AI products with different risk profiles. To evaluate its usefulness, the framework was applied to two real AI products with different characteristics. The evaluation shows that the classification mechanism leads to meaningfully different assessment processes depending on the product, and that the resulting question sets reveal AI-specific risks that a conventional supplier assessment would likely fail to capture.

1.1 Problem Description

ISO 27001 requires organisations to assess supplier risks, but does not specify what risks to look for in any particular technology. For AI products, information security professionals lack both the AI-specific risk knowledge and the structured assessment criteria needed to evaluate these products within their existing supplier assessment process. Existing AI governance standards and industry guides do not fill this gap. This thesis develops a vendor assessment framework that provides the missing criteria, structured as a practical extension of the ISO 27001 supplier controls.

1.2 Research Questions

The study aims to answer research questions focusing on identifying risks associated with AI-services, and proportionally assessing vendors with different risk profiles. The questions are as follows:

- What AI-specific information security risks should be addressed when evaluating AI products?
- How can AI products be classified to enable proportional supplier assessments?

1.3 Thesis Outline

This thesis is divided into the following sections.

Background provides the prerequisite knowledge needed to understand the contribution, covering information security fundamentals, ISO 27001 and its supplier assessment controls, how AI systems are delivered and classified, and the information security risks specific to AI systems. This section also reviews existing approaches to AI vendor assessments and identifies the gaps that motivate the framework.

Method describes the Design Science Research process used to develop and evaluate the framework, including problem identification, design objectives, the design and development process, and the evaluation approach.

Results presents the framework developed as the artifact of this thesis, including its scope, the two-axis classification, the assessment question batteries, and the end-to-end assessment process.

Evaluation applies the framework to two real AI products through illustrative scenarios, evaluates it against the design objectives, and discusses the limitations of the scenario-based evaluation.

Discussion answers the research questions based on the results and evaluation. It also discusses limitations of the study, and reflects on ethical and societal aspects.

Conclusions summarises the contributions and suggests directions for future work.

2 Background

This section covers the fundamental theory related to information security, supplier assessments, and the unique risks introduced by AI products.

2.1 Information Security and Classification

The fundamental goal of information security is to protect an organisation's information from unauthorized access, disclosure, modification, or destruction. In practice, this is often divided into the Confidentiality, Integrity, and Availability (CIA) triad[17, 53]. By aligning with standards such as ISO/IEC 27001, which is discussed in depth in section 2.2, organisations can establish an Information Security Management System (ISMS) to manage their risks and ensure confidentiality, integrity, and availability of their data.

Information classification is widely regarded as a fundamental prerequisite for an effective ISMS and is explicitly required by standards such as ISO/IEC 27001 [21]. The main objective of this process is to create a structured method for evaluating information assets based on the potential consequences of a security breach. By categorizing information according to its sensitivity and criticality to the organisation, they can ensure that the security measures implemented are proportional to the risk. This proportionality is essential, not only to prevent the leakage of sensitive data but also to avoid implementing an inefficient ISMS that would end up over-protecting non-critical information assets [6]. Information classification cannot be treated as a static, one-time activity. The sensitivity of accumulated data can change over time. Therefore, guidelines suggest that classification assessments must be integrated into the lifecycle of the system, requiring regular reviews, typically on an annual basis or during significant system updates, to ensure that the defined security controls remain aligned with the evolving risk of data aggregation and inference [40].

One common method when applying information classification is to label the sensitivity of information into different levels of the CIA triad depending on a consequence analysis [52]. The result could then be adapted to fit the organisation's needs. For instance, ISO/IEC 27002 provides a standard four-level baseline as an example, a common practical implementation among IT organisations is to separate the data into public, internal, confidential, and restricted levels [22].

The main advantages of this systematic approach for information classification is the ability to apply relevant security protocols specifically tailored to the information in question. This increases the efficiency of the organisations by ensuring that data is not overprotected, allowing users to apply relevant tools for their data without unnecessary

friction.

In the current regulatory landscape, it is often legally required to protect sensitive data [12]. Therefore, knowing exactly what data requires heightened protection is crucial to ensure that not everything is arbitrarily placed behind the most restrictive level of security. However, information classification is often a costly and time-consuming process. It may require additional roles such as information security experts to properly manage the process [15]. There is also the risk of limited adaptability if the classification scheme is too rigid. This lack of adaptability is a significant problem in the ever-evolving information technology industry, particularly with the emergence of increasingly capable AI tools, which may handle data in ways not anticipated by current classification models.

2.2 ISO/IEC 27001

Organisations that handle sensitive information need a systematic approach to protecting it. **ISO/IEC** 27001:2022 (ISO 27001) is the most widely adopted international standard for this purpose, specifying the requirements for establishing and maintaining an ISMS [23]. Rather than being a fixed set of security measures, the standard requires organisations to assess their own risks and select controls proportional to those risks from a catalogue defined in Annex A of the standard.

Annex A consists of 93 controls divided into four categories: organisational, people, Physical and Technological [21]. Looking at control 8.12, it states that “Data leakage prevention measures shall be applied to systems, networks and any other devices that process, store or transmit sensitive information.” Note that the control is formulated in a way that defines the intended outcome, but it does not prescribe any specific technical solution or mechanism for achieving it. Furthermore, all 93 controls do not need to be implemented to become ISO 27001 certified; rather, an auditor expects the organisation to apply the controls that address the risks relevant to their environment.

A key aspect of ISO 27001 is the management of risks arising from relationships with external parties. Annex A addresses this through controls 5.19–5.22, shown in Table 1, which require organisations to assess suppliers and ensure that appropriate security controls are applied throughout the supplier lifecycle. While ISO 27001 provides a foundation for managing information security risks, it is intentionally technology agnostic and does not prescribe detailed assessment criteria for specific types of systems or services. As a result, emerging technologies may introduce risks that are not fully captured by traditional vendor assessment practices aligned with the standard [21].

5.19	Information security in supplier relationships	Control Processes and procedures shall be defined and implemented to manage the information security risks associated with the use of supplier's products or services.
5.20	Addressing information security within supplier agreements	Control Relevant information security requirements shall be established and agreed with each supplier based on the type of supplier relationship.
5.21	Managing information security in the Information and Communication Technology (ICT) supply chain	Control Processes and procedures shall be defined and implemented to manage the information security risks associated with the ICT products and services supply chain.
5.22	Monitoring, review and change management of supplier services	Control The organization shall regularly monitor, review, evaluate, and manage changes in supplier information security practices and service delivery.

Table 1 ISO controls 5.19-5.22.

2.3 AI Systems

The increasing adoption of AI systems within organisations has introduced new challenges from an information security perspective, particularly when AI systems are procured as externally provided services. The 2026 AI Index reports that 88% of surveyed organisations used AI in 2025 and that generative AI was used in at least one business function at 70% of organisations [51]. In the context of this thesis, AI systems are primarily considered in the form of externally provided services, such as Software-as-a-Service (SaaS) solutions, procured from third-party vendors and integrated into organisational processes. This clarification is important, as it emphasises supplier dependencies and data flows rather than the internal technical implementation of the AI models. While generative AI systems such as Large Language Model (LLM)s represent the most prominent current driver of this trend, the framework developed in this thesis is not limited to generative AI and applies to any AI product procured as an external service.

2.3.1 The need for AI system classification

In traditional supplier assessments, the security-relevant properties of a system are largely determined by the data it processes. An organisation classifies the information that will be shared with or accessible to the supplier, and selects controls proportional to that classification. The type of system, whether it is a payroll application or an email service, is secondary. What matters is whether the system handles, for instance, public or restricted information. This approach works because traditional systems store, transmit, and transform data according to deterministic logic, and their capabilities are well understood from their product category alone.

AI systems break this assumption. The same underlying model can power products with vastly different risk profiles depending solely on how it is integrated. An LLM deployed as a stateless autocomplete feature in a word processor operates differently from the same model deployed as a stateful conversational assistant, which in turn operates differently from the same model deployed as an autonomous agent that can query databases, call APIs, and execute multi-step workflows. These are not different AI technologies, and they may be the same model, from the same vendor, processing the same data. What differs is what the system is able to do with that data and how much human oversight exists between the system's reasoning and its effect on the organisation's environment.

Current industry terminology does not resolve this ambiguity. AI products are commonly categorised as either generative AI, which produces content such as text, images,

or code, or agentic AI, which executes actions through tool use, API calls, and multi-step planning [19]. However, these categories describe the system’s capabilities rather than its operational relationship to the organisation. A generative AI product that drafts text for a human to review presents a different risk profile from a generative AI product that drafts and sends emails autonomously; again, both fall under the same industry label. For information security assessments, the relevant question is not whether the system generates or acts, but how much it can affect the organisation’s environment without human intervention.

This distinction matters because it directly determines the information security risk profile. Consider two AI products that both process confidential employee data. The first is an advisory system that answers questions about internal HR policies, and a human reads the response and decides what to do. If the system is compromised, the consequence is a bad recommendation that a human might recognise and discard. The second is an agentic system that reads an employee’s request, queries the HR database, drafts a response, and sends it without human confirmation. If this system is compromised, the consequence is an incorrect action that has already been executed and potentially affected other systems before anyone notices. The data sensitivity is identical, but the organisational risk is not.

Traditional classification approaches, whether based on application domain or data sensitivity alone, do not capture this difference. An assessment process that applies the same depth of scrutiny to both products will either over-assess the advisory tool or under-assess the agentic one. What is needed is a classification dimension that reflects the system’s operational autonomy. This involves what it can do, whether a human must approve before it acts, and how far the consequences of an error can propagate before intervention is possible. This dimension, combined with data sensitivity, provides the basis for a proportional assessment, one where the depth and focus of the evaluation correspond to the actual risk the product introduces. The framework developed in this thesis formalises this classification and uses it to determine the scope and depth of the vendor assessment.

2.4 Information Security Risks of AI Systems

Traditional information systems and services integrated into organisations are typically assessed using structured risk assessment processes aligned with standards such as ISO/IEC 27001. These assessments assume that system behaviour, data flows, and control implementations can be documented, verified, and audited [23]. However, when applied to AI systems, particularly those provided as external services, these assumptions do not always hold.

Taken together, the areas output integrity, behavioural stability, and data handling represent some of the information security risks that are missing from ISO-27001 connected vendor assessment processes. They also span all three dimensions of the CIA triad. Confidentiality is threatened by irreversible data embedding and opaque supply chains. Integrity is compromised by non-deterministic outputs and opaque reasoning. Availability is undermined by silent model changes that invalidate prior assessments. This motivates the need for assessment criteria that explicitly address these AI-specific properties when evaluating third-party AI services.

2.4.1 Confidentiality

The most consequential area, from an information security perspective, concerns how AI systems handle data. In a conventional SaaS product, customer data is processed, stored according to defined retention policies, and deleted on request. The data lifecycle is well understood and governed by controls such as ISO 27001 A.8.10 (Information deletion). AI systems introduce a fundamentally different data lifecycle. When customer data is used to train or fine-tune a model, it becomes embedded in the model's parameters and cannot subsequently be identified, extracted, or deleted [7]. This becomes a critical security issue, as the most common practice by AI model developers is to train on user data by default [25]. It is therefore crucial that organisations understand what happens to their input data.

This is not a data retention problem in the traditional sense, it is an irreversible transformation that renders standard deletion controls inapplicable. A vendor may truthfully confirm that all stored copies of a customer's data have been deleted, while that data remains permanently encoded in a production model serving other customers. Beyond training, AI systems may also expose data through inference-time memorisation, where a model reproduces fragments of its training data in response to specific prompts [7]. This creates a confidentiality risk that has no equivalent in conventional software. One customer's sensitive data may surface in another customer's session, not through an infrastructure failure or access control violation, but through the normal operation of the model itself. The OWASP LLM Top 10 lists both training data poisoning and sensitive information disclosure as top-level vulnerabilities, and notes that these attack vectors cannot be mitigated by standard controls such as network segmentation or access control lists alone [44].

AI systems can also infer new information by combining existing data, and this weakens existing information classification protocols. While a single user prompt may be classified as internal or low-sensitivity, the AI system acts as a massive data aggregator. Through the "mosaic effect," the system utilizes its pattern-recognition capabilities

to combine multiple low-sensitivity inputs and infer high-sensitivity outputs that were never explicitly present in any single source [20]. Because of this capability, the security classification of an AI system cannot only mirror the classification of a single input, it must instead reflect the highest potential classification of the aggregated information set it can derive.

2.4.2 Integrity

A fundamental divergence between AI systems and conventional software regarding the integrity of the outputs is the probabilistic nature of their outputs. Traditional systems process inputs through deterministic logic: the same input produces the same output, and deviations indicate a defect. AI systems, particularly those based on LLMs, are probabilistic, the same input may yield different outputs on repeated execution, and there is no guaranteed correspondence between the confidence of an output and its factual accuracy [49]. The OWASP Top 10 for LLM Applications identifies this as a distinct vulnerability, noting that AI systems can generate outputs that are fluent, internally consistent, and entirely fabricated, with no error signal to alert the user or any monitoring system [44]. This creates an integrity risk that is qualitatively different from conventional software defects: a database error produces an error code, but an AI hallucination produces a plausible answer that may be acted upon as if it were authoritative. The difficulty of validating such outputs is compounded by the opacity of the underlying models. The reasoning process that produced a given output is typically not accessible to the organisation, a property sometimes referred to as the black-box characteristic of AI systems [41]. Where traditional systems can be audited by inspecting their logic, AI outputs often cannot be traced back to a specific decision path, limiting the organisation's ability to verify whether a given result is correct.

The issue of output reproducibility is compounded by the instability of AI system behaviour over time. In conventional software, a change in behaviour requires a change in code. When a new version is deployed, a changelog is published, allowing the customer to test and validate the system before accepting the update. AI systems do not follow this transparent pattern, as model behaviour evolves dynamically over time through continuous training and adaptation to the context of previous input prompts. A vendor can retrain the underlying model, adjust its parameters, or replace the model entirely, and the customer-facing product may behave differently without any visible deployment event, version increment, or notification [20]. Security controls that relied on the AI behaving consistently, for example, a content classification rule or a data redaction filter, may silently degrade after a model update the customer was never informed of. This challenges the effectiveness of point-in-time assessments: an evaluation that was accurate at the time of procurement may no longer reflect the system's actual behaviour

months later. ISO/IEC 42001 acknowledges this by requiring organisations managing AI systems to address lifecycle risks including model retraining and performance monitoring (ISO/IEC 42001:2023, Annex A). However, while ISO 42001 governs how an organisation manages its own AI systems, it does not prescribe how to assess whether an external vendor’s lifecycle management is adequate.

2.4.3 Availability

The main concern for availability of AI systems lies in the complex and opaque supply chains. Many AI vendors do not develop their own models, but instead integrate third-party models through active API calls [9]. This creates a deeply layered architecture consisting of the immediate vendor, a model provider, and a cloud infrastructure operator. The main concern for the availability of AI systems lies in these complex and opaque supply chains. Because the immediate vendor does not host the core computational engine, any upstream outage, API rate-limiting, or sudden model deprecation by the foundation provider cascades directly to the end-user, rendering the vendor’s system completely unavailable [44]. ISO 27001 control A.5.21 requires organisations to manage information security within the Information and Communication Technology (ICT) supply chain, but this control fundamentally assumes that the supply chain is visible and contractually governed. In AI procurement, neither assumption reliably holds.

2.5 Related Work

This section surveys existing approaches to AI vendor assessments. Literature addressing this specific layer of the supply chain, the boundary between the AI product vendor and the procuring organisation, was scarce as it sits at the intersection of a well-established practice (supplier assessments) and a rapidly evolving technology domain (AI).

The most widely available resources addressing AI-specific security risks take the form of technical guidance documents rather than assessment tools. The OWASP Top 10 for Large Language Model Applications [46] catalogues vulnerabilities such as prompt injection, training data poisoning, and sensitive information disclosure. The OWASP Top 10 for Agentic Applications [45] extends this to autonomous systems, covering risks such as tool misuse, identity abuse, and cascading failures. These resources are valuable for understanding what risks exist, but they are written for organisations building or operating AI systems, not for organisations procuring them from external vendors. An information security practitioner evaluating a third-party AI product must independently determine which of these risks are relevant to the specific product, formulate appropri-

ate assessment questions, and decide what constitutes an acceptable vendor response. In effect, the practitioner must convert a threat taxonomy into a supplier assessment, a translation that requires both AI-specific knowledge and assessment design expertise. The frameworks discussed below represent attempts to bridge this gap.

2.5.1 Existing AI Vendor Assessment Frameworks

The **FS-ISAC** Generative AI Vendor Risk Assessment Guide [14], published in February 2024 for the financial services sector, produces one of three due diligence levels based on a risk analysis across five domains: use case, business integration, use of confidential data, business resiliency, and potential for exposure. Higher-risk scenarios trigger more extensive vendor questionnaires, and the questions included in each level are configurable. However, the FS-ISAC approach differs from the framework in this thesis in three respects. First, the tiering in FS-ISAC relies entirely on the organisation’s use case and business integration, without accounting for the technical capabilities of the AI product itself. Second, it is designed specifically for financial services and references sector-specific regulatory guidance, limiting its applicability to other industries. Third, the questionnaire does not include any form of evaluation guidance, leaving the interpretation of vendor responses entirely to the organisation’s internal risk methodology.

The Data & Trusted AI Alliance (DTA) released an AI Vendor Assessment Framework (VAF) in October 2025 [10]. The VAF provides a structured questionnaire across domains including privacy, security, explainability, compliance, fairness, and intellectual property. Each domain includes baseline questions that can expand into deeper diligence when certain conditions are met, for example when the model processes sensitive or regulated data, influences decisions about people, or is deployed in a regulated or customer-facing environment. The framework also includes guidance in each question with explanations of why each question matters and examples of strong vendor responses, making it accessible to non-technical buyers.

The VAF represents the most comprehensive existing AI vendor assessment instrument in terms of breadth, covering both risk and business value dimensions across seven domains. However, its tiering mechanism differs from the one developed in this thesis in two respects. First, deeper diligence in the VAF is triggered per domain based on contextual conditions such as regulatory environment and impact on individuals. These criteria are aligned with the EU AI Act’s domain-based risk classification rather than with the technical properties of the AI product itself. An autonomous AI system processing non-sensitive data in a non-regulated domain would not trigger deeper diligence under the VAF’s criteria, despite presenting significant integrity and availability risks through its ability to act without human oversight. Second, the tiering is applied per

question domain rather than globally. The same product may receive deeper diligence for privacy questions but baseline treatment for security questions. The framework developed in this thesis classifies the product once, based on operational autonomy and data sensitivity, and that single classification determines the entire assessment scope.

In April 2025, Ah King published the AI Vendor Security and Safety Assessment Guide [1], a practitioner-oriented resource intended for integration into existing third-party risk management workflows. The guide is structured around a set of internal preparatory questions covering impact assessment, data sensitivity, and business criticality, followed by a comprehensive set of vendor assessment questions spanning governance, regulatory compliance, ethical practices, data handling, security controls, robustness, explainability, supply chain risk, and operational security. In its introductory guidance, the document advises assessors to “focus your most thorough assessment on high-risk scenarios” and to “tailor the questions based on your organisation’s specific risk tolerance, industry regulations, data sensitivity, and the intended AI application” [1].

This advisory approach to prioritisation recognises the need for proportionality but does not formalise it into a structural mechanism. All vendor questions are presented regardless of the product’s properties, and the assessor must independently decide which to emphasise or omit. The guide also does not include evaluation guidance describing what constitutes an adequate vendor response. The questions are well-formulated, but the interpretation of answers is left to the assessor’s judgement.

2.5.2 Comparison

The existing approaches share the common purpose of helping organisations evaluate AI vendors before procurement. Where they differ is in scope, intended audience, and the degree of structure surrounding the assessment process. Table 2 summarises the key differences.

No existing approach classifies the AI product based on its technical properties before assessment begins. FS-ISAC tiers by organisational context, the VAF tiers per domain based on deployment conditions, and Ah King advises prioritisation without providing a mechanism to enact it. None of the three tiers on operational autonomy, which, as argued in Section 2.3.1, is the dimension that most directly determines the blast radius of an AI failure or compromise. The VAF provides evaluation guidance, but its tiering does not account for what the system can do without human oversight. Ah King covers the broadest range of AI-specific risks but assumes a level of technical understanding that limits its usability for the intended audience of this thesis.

The framework developed in this thesis addresses these gaps. It classifies the AI product

Capability	FS-ISAC	VAF	Ah King
Risk-based tiering	Yes	Yes	Advisory
Tiering by product properties	No	No	No
Global tier (one per product)	Yes	No	Yes
Evaluation guidance per question	No	Yes	No
Sector-independent	No	Yes	Yes

Table 2 Comparison of existing AI vendor assessment approaches.

by operational autonomy and data sensitivity, uses that single classification to determine the scope of the entire assessment, and includes evaluation guidance with each question describing what a good answer looks like, bridging the gap between AI-specific risks and the security-oriented competence of the intended user.

3 Method

The following chapter describes the applied method of Design Science Research.

3.1 Design Science Research

Design Science Research (DSR) is a method used to generate knowledge by designing and evaluating artifacts to real-world problems [16]. This method is suitable for this thesis, as it aims to bridge the gap between current information security standards and AI-specific challenges.

In the context of DSR, Information Technology artifacts can be categorized as constructs, models, methods, or instantiations [16]. In this thesis, the artifact that was developed is an AI-specific vendor assessment framework, extending the supplier assessment controls of ISO 27001. The artifact can be considered a model and a method since the classification mechanism, which maps product properties to assessment tiers, constitutes a model, whereas the assessment process and question batteries constitute a method that turns the model into a repeatable practice.

While Hevner et al. provide the conceptual foundation for understanding what constitutes a design science artifact, they do not prescribe a concrete process for carrying out the research. This study therefore adopts the DSR process model proposed by Peffers et al. [48], which defines six distinct steps:

1. Problem identification and motivation
2. Definition of solution objectives
3. Design and development
4. Demonstration
5. Evaluation
6. Communication

These steps are illustrated in Figure 1. This structured approach ensures that the resulting artifact is not only theoretically grounded but also systematically developed and empirically demonstrated. The application of each step to this thesis is described in Section 3.2.

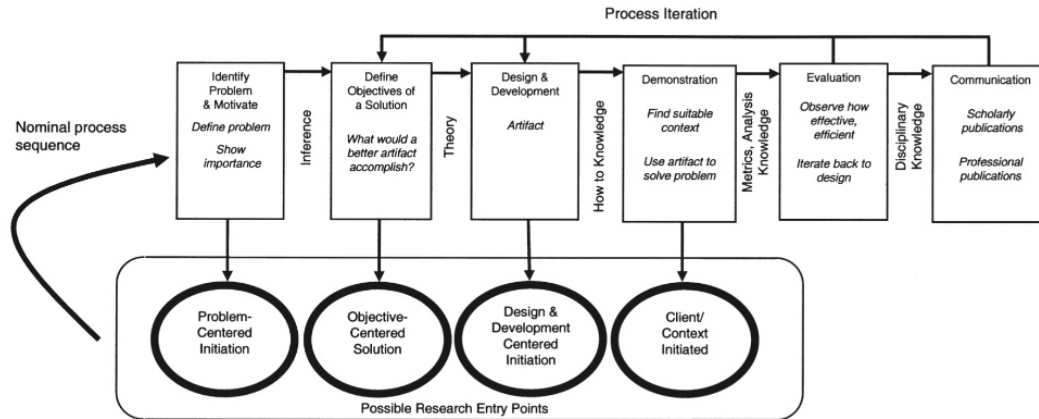


Figure 1 The Design Science Research Process Model (DSRM), suggested by Peffers et al. [48].

3.2 Application of DSRM

This section describes how each step of the DSRM was enacted in this thesis.

3.2.1 Step 1 - Problem identification.

ISO 27001 requires organisations to assess and monitor the information security practices of their suppliers through controls A.5.19–5.22. These controls establish requirements for supplier agreements, but they are technology-neutral by design. They do not distinguish between a conventional SaaS product and an AI-powered service, nor do they address risks specific to AI systems. As organisations increasingly procure AI-embedded tools, this creates a gap. The standard requires a supplier assessment, but the controls do not guide the assessor toward the questions that matter for AI products specifically.

This gap was observed in practice through the thesis collaboration with a Swedish cybersecurity consultancy. The firm’s **CISO**, who supervises this thesis, identified that existing supplier assessment processes built on ISO 27001 failed to surface AI-specific risks during vendor evaluations.

A review of the academic literature and available industry resources confirmed that this is not an isolated concern. As discussed in Section 2.5, the most widely available resources addressing AI-specific security risks take the form of technical guidance documents and broad checklists rather than structured assessment frameworks integrated into

existing ISMS processes. Practitioners must independently interpret these resources and translate them into supplier assessment questions, a task that requires AI-specific expertise that an Information Security professional cannot be assumed to possess [1].

The problem addressed in this thesis has two main dimensions. First, the ISO 27001 supplier controls lack the specificity needed to guide an assessment of AI vendors. Second, existing AI-specific resources do not provide a structured and integrated method that practitioners without AI expertise can apply within an existing ISMS. This creates a need for a structured assessment framework that extends ISO 27001 supplier controls with AI-specific assessment questions and classifies AI products by their risk properties to determine the appropriate depth of scrutiny.

3.2.2 Step 2 - Design objectives.

The design objectives were derived from the problem identified in Step 1 and from the study's two research questions. Step 1 showed that existing ISO 27001-based supplier assessment processes do not capture AI-specific information security risks, while available AI-specific resources are not sufficiently structured or integrated to support practical supplier assessment within an existing ISMS. The objectives, therefore, define what the artifact must achieve to address this problem in practice.

The first two objectives correspond directly to the study's research questions and define the core functional requirements of the artifact:

O1 - AI-specific risk identification. The framework should identify the information security risks that should be addressed when evaluating AI products. This objective follows from the problem identified in Step 1 that ISO 27001 supplier controls do not explicitly guide assessors toward AI-specific concerns. The artifact must therefore translate such concerns into questions that can be used in supplier evaluations.

O2 - Classification-driven proportionality. The framework should classify AI products based on risk-relevant properties in order to determine an appropriate depth and scope of supplier assessment. This objective follows from the need identified in Step 1 for a structured way to differentiate between AI products so that low-risk products are not over-assessed and high-risk products are not under-assessed.

In addition to these core objectives, the artifact must satisfy two supporting design objectives to be applicable in the intended organisational context:

O3 - ISO 27001 integration. The framework should function as a supplement to existing ISO 27001 supplier assessment processes (A.5.19–5.22), not as a standalone tool. The intended user already operates an ISMS, and an assessment framework that requires a different process is unlikely to be adopted. The framework should be usable within existing supplier evaluation workflows without restructuring them.

O4 - Practitioner accessibility. The framework should be usable by information security practitioners without requiring specialist expertise in AI or machine learning. This follows the fact that current AI-specific guidance often requires practitioners to interpret technical material and translate it into assessment questions.

Together, these objectives define both what the artifact must do and the conditions under which it should be usable. O1 and O2 operationalise the study's two research questions, while O3 and O4 ensure that the resulting framework is compatible with ISO 27001 practice and usable by its intended audience.

These objectives correspond to the research questions as follows. RQ1, which asks what AI-specific information security risks should be addressed when evaluating AI products, is operationalised through O1. RQ2, which asks how AI products can be classified to enable proportional supplier assessments, is operationalised through O2. O3 and O4 function as supporting design objectives that ensure the artifact can be applied in the organisational setting defined by the study.

3.2.3 Step 3 - Design and development.

The design drew on two categories of input: the knowledge base (ISO 27001 controls, AI risk literature, and existing assessment approaches reviewed in Section 2.5) and the practice environment (the case organisation's experience with supplier assessments). The following paragraphs describe how each component was developed and what design decisions shaped them.

Classification The classification system required selecting dimensions along which AI products could be differentiated for the purpose of determining assessment depth. Existing approaches classify AI systems by application domain [11], by technical capability spectrum [19, 18], or across analytical dimensions intended for policy analysis [43]. These classifications serve their respective purposes but do not address what a supplier assessor needs to determine: how much scrutiny this specific product requires.

The first axis selected was operational autonomy, defined as the degree to which the system can take actions within the organisation’s environment without human intervention. This dimension was chosen because it directly shapes the risk profile from a supplier assessment perspective: a system that generates suggestions for a human to review introduces fundamentally different risks than a system that autonomously modifies files, sends messages, or calls external APIs. The AI risk scenarios identified in Section 2.4 confirmed this.

The second axis selected was data sensitivity, reflecting the confidentiality of the information the system processes. This axis was included because it is already familiar to practitioners performing supplier assessments under ISO 27001, where data classification is a standard input to risk decisions. Including it ensures that the framework aligns with existing organisational practices and captures the dimension that conventional assessments already rely on.

The two axes were combined into a classification matrix where the highest-risk axis determines the assessment tier. This highest watermark principle ensures that a product processing low-sensitivity data but operating autonomously still receives deeper scrutiny. The specific autonomy levels, data sensitivity levels, and resulting tier assignments were refined through discussion with the supervising CISO and are presented in Section 2.1. Early iterations considered a finer-grained autonomy scale with four levels, which was later simplified to three after the distinction between two of the levels did not produce different tier assignments in practice.

Assessment questions. The question set was derived from the AI-specific risk scenarios identified in Section 2.4. For each scenario, candidate questions were formulated by considering how the risk would appear in a supplier relationship and what information the assessor would need from the vendor to evaluate it.

Three sources informed this process. First, ISO 27001 Annex A controls, especially A.5.19–5.22, were examined to identify which AI-specific risks fall outside the standard’s scope. Second, the Vendor Assessment Framework [10] and Ah King’s assessment guide [1] were reviewed question-by-question to identify risk areas they cover only partially or do not address at all. Questions addressing those gaps were prioritised for inclusion.

Each question was mapped to one or more CIA dimensions (confidentiality, integrity, and availability). This mapping was used as a traceability mechanism to check that coverage was not concentrated in only one dimension, rather than to suggest that all AI risks can be reduced to the CIA triad.

The questions were then divided into two tiers. The baseline tier contains questions relevant to all AI products, such as those concerning training data handling, data retention, and administrative controls. The deeper diligence tier contains questions relevant only when the product's autonomy introduces additional risks, such as credential inheritance, transaction limits, or prompt injection via tool outputs. In practice, a question was placed in the deeper diligence tier when the risk it addressed depended on the system's ability to act autonomously.

Each question was supplemented with evaluation guidance consisting of a short explanation of why the question matters and what would constitute an adequate vendor response. This was intended to support O4 by helping practitioners interpret vendor documentation without requiring AI-specific expertise.

The question set was revised through repeated comparison with the illustrative scenarios in Step 4. This process was used to identify vague questions, overlaps between questions, and uncovered risk areas. As a result, several questions were merged, new questions were added, and the evaluation guidance was clarified where the initial wording proved difficult to apply to real vendor documentation.

3.2.4 Step 4 - Demonstration.

The framework was demonstrated by applying it to two real-world AI products using publicly available vendor documentation as input. The two products were purposively selected to differ on the autonomy axis while sharing the same data sensitivity level (D2, Internal). This isolates the classification mechanism by showing that any difference in assessment output is due to the autonomy.

The first product, Miro AI, is a HITL AI feature embedded in an existing collaboration platform. The user initiates each interaction and reviews all output before it reaches the board. The second product, Claude CoWork, is an autonomous AI agent that executes multi-step tasks across local files and connected cloud services without requiring human approval for each action. Together, the two products differ in regards to the autonomy spectrum while holding data sensitivity constant.

For each product, the framework was applied in full. The product was classified across both axes, the resulting assessment tier was determined, and the corresponding question battery was applied using the vendor's publicly available documentation. The demonstration examines whether the classification mechanism assigns different tiers to the two products, whether different question sets are applied as a result, and whether the resulting findings differ in severity.

3.2.5 Step 5 – Evaluation.

Step 4 demonstrated that the framework can be applied to real products, and that the classification mechanism produces differentiated assessment processes. Step 5 asks a different question: does the framework satisfy the design objectives defined in Step 2?

The artifact developed in this thesis is a framework that has not yet been deployed in organisational practice. The evaluation is therefore conducted *ex ante*, using analytical methods appropriate for a design-stage artifact. Following the evaluation taxonomy developed by Peffers et al. [47], the method applied is among the most commonly used for framework and method artifacts in DSR.

The method is an *illustrative scenario*, in which the artifact is applied to real products using publicly available vendor documentation. The two product assessments from Step 4 serve as the basis for this evaluation. Where Step 4 asked whether the framework produces different outputs for different products, the evaluation asks whether those outputs satisfy the design objectives. This does not constitute a full usability evaluation with practitioners, but it provides initial evidence that the framework can be applied without specialist technical knowledge.

A limitation of this evaluation approach is that it does not include empirical user testing or deployment in an organisational setting. The evaluation is designed to assess whether the framework produces structured, differentiated assessments and whether it covers risks beyond existing approaches, but it cannot confirm that practitioners find it usable in practice or that it changes procurement decisions. These would be appropriate next steps for future research once the framework has matured beyond its current design stage. The evaluation results are presented in Section 5.

3.2.6 Step 6 - Communication.

The communication of the research is realised through this thesis. It presents the problem, the design and development of the artifact, and the results of its demonstration and evaluation. The thesis is written to address both an academic audience, by following the DSR methodology, and a professional audience, by providing a practically applicable framework for assessing AI suppliers in an ISO 27001 context.

4 Results - The Framework

This section presents the framework created as an artifact for this thesis.

4.1 Scope

The framework developed in this thesis operates at the boundary between the vendor of an AI product and a procuring organisation. Its purpose is to support the procurement decision: given an AI product from a vendor, does the product meet the organisation's information security requirements? The intended user is an information security professional, typically a CISO or information security officer, who is responsible for supplier assessments within an ISO 27001 ISMS. This person is assumed to have experience with information security risk assessments, but not necessarily with machine learning or LLM development. To bridge any knowledge gap, each assessment question includes guidance that explains why the question matters and what constitutes a satisfactory vendor response.

This scope is deliberately bounded to this layer of the supply chain, since the framework does not assess foundation model providers directly. The procuring organisation typically has no direct contractual relationship with the entity that built the underlying model and limited practical means of conducting due diligence on their practices. Instead, the framework addresses this indirectly through questions that evaluate the vendor's transparency about its own supply chain.

Equally, the framework does not address what happens after a product has been approved. Internal AI governance, policies, oversight mechanisms, and operational controls that an organisation applies once an AI product is in use fall within the scope of standards such as ISO/IEC 42001, which specifies requirements for an AI management system [24]. ISO 42001 and the framework presented here serve different purposes: ISO 42001 governs how an organisation manages AI it has chosen to use, while this framework helps the organisation decide whether to approve a specific AI product in the first place. An organisation could hold both an ISO 27001 and an ISO 42001 certification and still lack a structured method for evaluating whether a particular vendor's AI product meets its security requirements. That is the gap this framework addresses.

4.2 Classification

Before any assessment questions are asked, the framework requires the assessor to classify the AI product along two axes: the sensitivity of the data the product will process, and the level of operational autonomy the product exercises. Together, these two axes determine whether the product requires a baseline assessment or a more extensive, deeper diligence assessment.

The rationale for this classification step was established in Section 2.3.1, but boils down to the fact that traditional supplier assessments determine depth based on data sensitivity alone. However, AI products with identical data access can present fundamentally different risk profiles depending on what the system can do without human intervention. The classification mechanism addresses this by combining both dimensions into a single assessment tier.

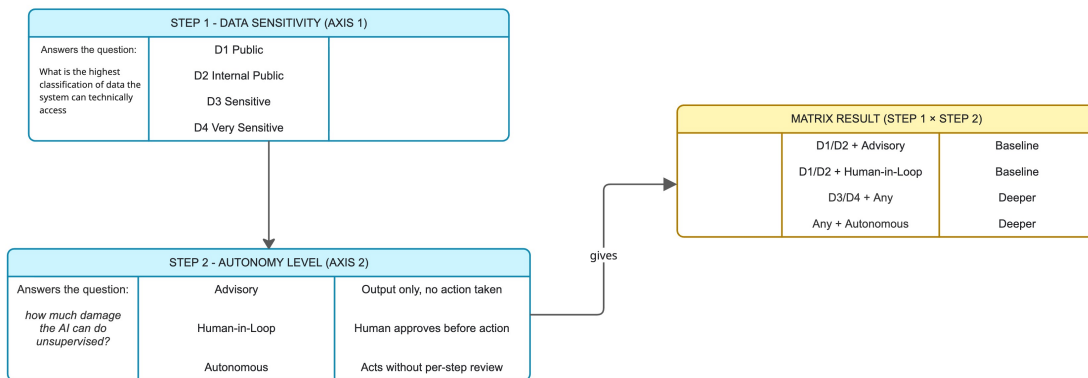


Figure 2 The classification process. Step 1: Determine data sensitivity. Step 2: Determine operational autonomy. The combination produces the assessment tier.

4.2.1 Data Sensitivity

The first axis captures the sensitivity of the data the AI product will process. Most organisations operating an ISMS under ISO 27001 already maintain an information classification scheme as part of control A.5.12 (Classification of information). The framework builds on this existing practice rather than introducing a separate classification. The assessor determines the data sensitivity level based on the organisation's own classification policy, applied to the data the AI product will have access to.

The framework defines four levels of data sensitivity:

- D1 - Public.** Information that is freely available or intended for public disclosure. Processing this data through an AI product introduces minimal confidentiality risk. Examples include published marketing materials, public documentation, or open-source code.
- D2 - Internal Public.** Information intended for use within the organisation but not classified as confidential. Unauthorised disclosure would not cause significant harm but is undesirable. Examples include internal meeting notes, project plans, and general business correspondence. This is the most common classification for data processed by productivity and collaboration tools.
- D3 - Sensitive.** Information whose disclosure could cause material harm to the organisation or to individuals. This includes personal data protected under GDPR, client-related information subject to non-disclosure agreements, financial data, and strategic business plans. AI products processing D3 data require closer scrutiny of the vendor's data handling, retention, and sub-processor practices.
- D4 - Very Sensitive.** The most sensitive category, covering information whose disclosure could cause severe harm. Examples include trade secrets, regulated health data, classified government information, or data subject to specific legal restrictions on processing. AI products intended to process D4 data trigger the highest level of assessment scrutiny regardless of the product's autonomy level.

When assessing data sensitivity, the assessor should consider not only the data the organisation intends to send to the product, but also data the product may access through integrations or permissions. An AI assistant embedded in an email client may technically have access to the entire mailbox, even if the organisation only intends to use it for drafting replies to internal messages. **The effective data sensitivity is determined by what the product can access, not only what the organisation plans to use it for.**

4.2.2 Operational Autonomy

The second axis captures how much the AI product can affect the organisation's environment without human intervention. As argued in Section 2.3.1, this dimension is what distinguishes AI products from conventional software in terms of information security risk: two products processing identical data present different risk profiles if one merely displays suggestions while the other executes actions independently.

The framework defines three levels of operational autonomy:

Advisory. The system produces output like text, scores, recommendations, summaries, classifications that a human reads and acts on independently. The AI has no ability to trigger actions, modify data, or interact with other systems. If the output is wrong, the consequence depends entirely on whether the human recognises the error. Examples include AI-powered search, content generation tools, and recommendation engines that display results without acting on them.

Human-in-the-Loop. The system's output is connected to a system action, but a human must explicitly approve before that action executes. The AI influences the content of the action, but cannot proceed without confirmation. Examples include an AI that drafts an email for the user to review and send, or a system that proposes document edits that the user must accept. The human functions as a control gate between the AI's reasoning and its effect on the environment.

Autonomous. The system executes actions without requiring human approval for each individual action. This level covers a spectrum of capability. At one end, a system may perform a single predefined action per trigger, such as automatically classifying and routing incoming support tickets. At the other end, a system may plan and execute sequences of multiple actions, use external tools or APIs, and adapt its approach based on intermediate results, for example, an AI assistant that reads a request, searches a knowledge base, drafts a response, and sends it as one uninterrupted chain. What these systems share, and what distinguishes them from the previous two levels, is that errors take effect before a human can intervene.

The assessor determines the autonomy level based on what the product can do in the organisation's intended deployment. A product described as AI-powered may operate at the Advisory level if it only generates suggestions, or at the Autonomous level if it executes actions through API calls.

The two axes combine to produce one of two assessment tiers, Baseline or Deeper diligence. As seen in Figure 2, the assignment also follows a highest-watermark principle, meaning that if either axis indicates elevated risk, the product is assessed at the higher tier.

4.3 Assessment Questions

Once the product has been classified and the assessment tier determined, the assessor applies the corresponding question battery. The framework defines two sets of questions: a baseline battery that applies to all AI products regardless of classification, and

a deeper diligence battery that is added for products whose classification indicates elevated risk. Products in the Baseline tier receive only the baseline questions. Products in the Deeper diligence tier receive both.

Each row in the question battery follows a consistent structure:

Component	Description
The question itself	What the assessor asks the vendor. Questions are written in plain language to be included in a supplier assessment questionnaire or discussed during a vendor meeting.
Why it matters	A brief explanation of the risk the question addresses and why it is relevant to AI products specifically. This helps the assessor understand the purpose of the question even without prior knowledge of the underlying AI concept.
What a good answer looks like	Evaluation guidance describing what an adequate vendor response should contain, what partial or evasive responses look like, and what findings should be flagged for follow-up. This component bridges the gap between the AI-specific nature of the question and the security-oriented competence of the assessor.
CIA mapping	Each question is tagged to confidentiality, integrity, availability, or general information security governance, ensuring traceability to the risk categories that underpin the framework's scope.

Table 3 Structure of each assessment question in the framework.

The complete question batteries, including all evaluation guidance, are presented in Appendix A. The following subsections describe the purpose and coverage of each battery and present representative examples to illustrate the structure.

4.3.1 Baseline

The baseline battery covers information security risks that are inherent to any AI product, regardless of its autonomy level or the sensitivity of the data it processes. These are risks that arise from the fundamental properties of AI systems discussed in Section 2.3: the potential irreversibility of training on customer data, the opacity of the AI supply chain, and the possibility of silent model updates. The baseline battery contains 18 questions.

Table 4 presents a representative question from the baseline battery to illustrate how the structure described above is applied in practice.

Component	Content
Question	Does the vendor use customer input data for model training or fine-tuning?
Why it matters	When customer data is used to train an AI model, the information is absorbed into the model's parameters and cannot subsequently be identified, extracted, or deleted. This is fundamentally different from data retention, where stored data can be purged after a defined period. If the vendor trains on customer data, the organisation faces an irreversible data exposure that standard deletion controls under ISO 27001 (A.8.10) cannot address.
What a good answer looks like	The vendor should clearly state whether customer data is used for training, and under what conditions (opt-in, opt-out, or mandatory). An adequate response includes a contractual commitment in the data processing agreement. Responses that conflate training with inference-time processing, or that describe anonymisation without specifying the method, should be flagged for follow-up.
CIA mapping	Confidentiality

Table 4 Representative baseline question: training data use.

4.3.2 Deeper Diligence

The deeper diligence battery covers risks that emerge specifically when an AI product operates autonomously or processes highly sensitive data. These questions are applied in addition to the baseline battery, not as a replacement. Some deeper diligence questions apply to all products in the tier, while others are conditional on the product's capabilities. The deeper diligence battery contains 13 questions.

4.4 Assessment Process

This section describes the end-to-end workflow for applying the framework. The process is designed to fit within an existing ISO 27001 supplier assessment procedure, supplementing rather than replacing the organisation's current approach.

1. **Identify the AI product.** Determine whether the product or service being assessed includes AI features. This may be a dedicated AI product being procured, or an AI capability being introduced into a product the organisation already uses. If AI features are present, proceed with the framework.
2. **Classify the product.** Determine the data sensitivity level (D1–D4) based on the organisation’s information classification policy, applied to the data the product will have access to. Determine the operational autonomy level (Advisory, Human-in-the-Loop, Autonomous) based on the product’s actual capabilities in the planned deployment. Use the classification matrix from Figure 2 to determine the assessment tier.
3. **Select the question battery.** If the product is classified as Baseline, apply the baseline question battery. If classified as Deeper diligence, apply both the baseline and deeper diligence batteries. For deeper diligence products, note which questions are scoped to the product’s specific autonomy level.
4. **Conduct the assessment.** Apply the selected questions. Sources of information may include the vendor’s public documentation, privacy policies, terms of service, security certifications, and direct responses to a supplier assessment questionnaire. Use the evaluation guidance for each question to assess the vendor’s response.
5. **Inform the procurement decision.** Present the assessment record to the decision-maker. The record provides the structured evidence needed to make an informed decision based on the organisation’s risk appetite. The framework does not prescribe the decision, but it ensures the decision is based on a systematic evaluation rather than an ad hoc review.

This process can be applied at the point of initial procurement (A.5.19), referenced during contract negotiation (A.5.20), and repeated when the vendor introduces significant changes to the AI features (A.5.22). The classification should be reviewed if the organisation’s intended use of the product changes, for example, if a product initially deployed at the Advisory level is later granted permissions that elevates it’s autonomy.

5 Evaluation - Illustrative Scenario

This section evaluates the framework developed during this thesis. Section 5.1 and 5.2 applies the framework to two AI products through illustrative scenarios to demonstrate that the classification mechanism produces differentiated assessment processes. Section 5.3 synthesises the evidence to evaluate whether the framework satisfies its design objectives.

5.1 Illustrative Scenario A: Miro

The following scenario demonstrates the framework’s practical application by evaluating Miro, a collaborative enterprise whiteboarding platform. This assessment illustrates how the framework handles existing SaaS tools that have retroactively integrated generative AI features.

5.1.1 Context

The firm uses Miro boards for client workshops, strategic planning sessions, and project plans. Board content routinely includes client names, project details, internal strategy discussions, and workshop outputs. The organisation classifies the data present on Miro boards as D2 - Internal.

Regarding operational autonomy, the Miro AI functionality generates content such as diagrams and summaries in response to user prompts. The generated content appears on the board for the user to review, edit, retain, or discard. This corresponds to the Human-In-The-Loop level in our framework, since the system produces output as suggestions that a human reviews before insertion.

The complete baseline assessment for Miro is presented in Appendix B. The combination of Internal data and the Human-In-The-Loop autonomy level requires the assessor to apply only the baseline questions.

This restriction demonstrates a core property of the framework: preventing assessment fatigue. Unlike an autonomous agent, Miro AI cannot execute actions, modify existing board content without user initiation, or authenticate to external third-party services. Therefore, the assessment does not need to cover agentic risks like transaction limits, cascading failures, or credential inheritance. Instead, the baseline battery appropriately directs the assessor’s focus entirely toward the data layer: how input is protected, where it flows in the supply chain, and how the resulting output is governed.

Before applying the framework’s specific questions, the assessor should note the vendor’s general governance posture. Miro holds SOC 2 Type II and ISO 27001 certifications [30]. Additionally, Miro has obtained ISO/IEC 42001 certification, which addresses the responsible development and deployment of AI systems [30]. The presence of ISO 42001 is notable because it indicates that Miro has subjected its AI practices to external audit against an AI-specific standard. Building on this foundation, The following selected findings illustrate critical risks and governance gaps that a traditional IT supplier assessment would typically overlook. Some questions highlighted gaps in publicly available documentation, indicating exactly where an assessor would need to initiate direct vendor dialogue.

5.1.2 Confidentiality

One of the first questions the framework asks is whether the vendor uses customer data to train or fine-tune AI models. Miro’s security documentation states that customer data is not used to train Miro AI models [29]. The AI terms add further detail: for enterprise customers, Miro commits to obtaining consent before using any input or output to improve AI features, while non-enterprise customers are instead given the option to object [27]. This means the implementation of the safeguard depends on the customer’s plan. For the enterprise deployment evaluated here, the commitment is contractually clear. It is worth noting, however, that an organisation on a lower-tier plan would receive a weaker default protection, something an assessor should be aware of if the tool is used across different parts of the organisation with different subscription levels.

Beyond internal data handling, the framework also asks whether the vendor discloses which third parties are involved in processing customer data when AI features are used. Miro’s privacy policy notes that AI features may share limited data with Microsoft [30]. This tells us who the upstream model provider is, but not what exactly is being shared, whether it is the full text of the user’s prompt, metadata about the interaction, or something in between. This is an example of the kind of supply chain opacity discussed previously. The organisation can see who is in the chain, but not what flows through it. The framework goes a step further by asking about the scope of data shared with the model provider, which reveals a gap that traditional supply chain controls do not reach.

5.1.3 Integrity

The framework investigates whether the vendor is aware of AI limitations and implements measures against hallucinations. Because the underlying large language models are inherently probabilistic and lack an independent mechanism to verify facts [38], out-

puts may be inaccurate. Miro explicitly addresses this in its AI terms by disclaiming the accuracy of AI outputs and placing the responsibility squarely on the customer to independently verify all generated content [27]. While no automated output-side safeguards against hallucinations are documented, this is an acceptable risk given the low autonomy level of the product, where human review is a mandatory step before any output is applied.

Closely tied to the risk of inaccurate outputs is the question of the content's origin. The framework asks whether AI-generated content can be distinguished from human-created content. While Miro's AI principles reference transparency, the assessment revealed that in practice, AI-generated content appears visually identical to manually created work. Consequently, once AI output is placed on the canvas and edited by a user, its origin becomes untraceable. If an AI hallucinates a business metric or strategy point that is later relied upon, the organisation cannot systematically identify that the flawed data originated from an AI model.

5.1.4 Availability

The framework asks whether the organisation can control the availability of the AI features. Miro allows enterprise administrators to enable or disable Miro AI for their organisation [29, 28]. This is a basic but important finding, particularly for AI capabilities embedded in existing products. The organisation did not originally procure Miro as an AI product, the AI was added later. Having the ability to keep the feature disabled while conducting an assessment and to restrict it afterwards if needed is itself a meaningful control.

5.2 Illustrative Scenario B: Claude CoWork

The second scenario demonstrates the framework's application to highly autonomous systems within an enterprise environment by evaluating Claude CoWork, an AI agent capable of interacting with local files and external cloud services.

5.2.1 Context

Claude CoWork is an AI agent, developed by Anthropic, that integrates workplace tools to autonomously perform multi-step tasks on behalf of the user. CoWork can read and modify local files, execute code, browse the web, and connect to external services such as Google Drive, Slack, and GitHub through Anthropic's Model Context Protocol

(MCP) connectors [4]. In this scenario, the procuring organisation intends to deploy CoWork for processing non-sensitive, internal data. This could be for drafting project updates, organising repositories, and summarising meeting notes.

The first step of the framework requires classifying the product across both axes. For data sensitivity, the organisation restricts CoWork to non-sensitive internal data. This evaluates to D2 (Internal), the same level as in the Miro scenario. Based on data sensitivity alone, this would suggest a baseline assessment. For operational autonomy, CoWork executes multi-step workflows, can call external APIs, reads and modifies files, and takes actions without requiring human approval for each individual step. Under the framework's taxonomy, this classifies the system as Autonomous.

Applying the highest watermark principle, the system's Autonomous classification overrides the low data sensitivity and escalates the product to the Deeper diligence tier. Without the autonomy-driven escalation, a traditional assessment based solely on the data classification would subject this tool to the same level of assessment as Miro. However, the nature of CoWork introduces risks that are independent of the data it is intended to process. An autonomous agent that can send Slack messages, modify files, and create GitHub issues operates with a fundamentally different risk profile from an advisory or Human-In-The-Loop (HITL) tool that processes identical data.

The deeper diligence battery was applied using publicly available documentation, and the complete assessment is presented in Appendix C. The following findings illustrate risks that would not be surfaced by a baseline assessment and have no equivalent in the Miro scenario. Several questions could not be fully answered from public documentation alone, particularly those concerning internal governance processes and contractual terms available only to enterprise customers. These gaps are themselves a finding since they indicate where the assessor would need to ask the vendor directly. Consequently, some entries in Appendix C document the absence of public information rather than a vendor response.

5.2.2 Confidentiality

The first question under the confidentiality section of the framework asks what tools the AI system has access to and what permission scope the tools have. CoWork authenticates to external services that support the MCP protocol. These connections authenticate with the user's own OAuth credentials, inheriting the full permission scope of whatever the user has access to [4]. There is no documented mechanism for creating a scoped identity for CoWork that is more restricted than the user's own permissions. For local files, the VM sandbox limits access to explicitly granted folders [5], but this scoping does not extend to connected cloud services. The blast radius of a compromised

CoWork session equals the full access scope of the authenticated user across all connected services. For Miro, this question is irrelevant since the system generates content on a board but never authenticates to external services.

The framework also asks whether the system maintains memory or context across sessions. CoWork does not retain conversational memory, but folder instructions, which CoWork can update autonomously during a session, persist across sessions and are loaded automatically in future sessions [4]. Sensitive information from processed files may be written into these instructions without the user’s explicit approval, creating data retention outside the vendor’s standard policies. This question highlights an aspect to be aware of: should the model be poisoned, the folder instructions are something to be aware of.

5.2.3 Integrity

The framework asks whether guardrails prevent sensitive actions without explicit confirmation. CoWork enforces deletion protection, requiring user approval before permanently deleting files [5]. However, this mechanism is inherently fragile in agentic systems, since safety ultimately depends on the LLM’s own judgment to recognize that a situation is sensitive in the first place. As recent research has shown, such judgment is probabilistic rather than deterministic. A safety monitor built on an LLM may correctly deny unauthorized actions most of the time, but the remaining failures are vulnerable [8]. Prompt-based defenses, such as instructing the model to never delete files without user confirmation, offer only modest improvements. Zhang et al. evaluated 16 popular LLM agents and found that none achieved a safety score above 60%, concluding that reliance on defense prompts alone is insufficient to address safety issues in agentic environments [54].

For a HITL product like Miro, this question does not apply because the system cannot take fully autonomous actions. For an autonomous product, the absence of transaction limits means a single misinterpreted instruction could trigger a large volume of unintended actions within permitted boundaries before anyone notices.

The framework also asks whether the system is protected against indirect prompt injection via tool outputs. Anthropic explicitly acknowledges this as an open risk [5]. The VM sandbox contains the effects of a successful injection within permitted boundaries, and a separate system mitigates web-based injection. However, within those boundaries a successful injection could cause CoWork to take unintended actions on permitted files or connected services, or write malicious content into the persistent folder instructions described above. This creates a link between the integrity and confidentiality findings: a prompt injection could not only cause immediate harm but also poison the persistent

context that shapes future sessions.

5.2.4 Availability

Under Availability, the framework only asks whether AI components are explicitly covered by the vendor's SLA. CoWork is released as a research preview and is explicitly excluded from standard enterprise SLAs, uptime commitments, and contractual remedies at the time of writing[4]. For an organisation considering deployment, this means there is no recourse if the service becomes unavailable during a critical workflow. Any supplier assessment would flag the absence of an SLA, but the framework's contribution is ensuring this question is asked of the AI component specifically, rather than assuming that an organisation's existing agreement with the vendor covers newly added AI capabilities. This question is placed in the deeper diligence battery because autonomous systems create availability dependencies that are more consequential than those of advisory or HITL tools.

5.3 Evaluation Against Design Objectives

This section reviews the results from the illustrative scenarios to evaluate whether the framework satisfies each design objective defined in Section 3.2.

O1: AI-specific risk identification. The framework should identify information security risks that should be addressed when evaluating AI products. This objective is supported by findings from both illustrative scenarios. The Miro assessment identified AI-specific concerns such as supply chain opacity and the absence of model change notifications, while the Claude CoWork assessment identified credential inheritance risks, persistent context exposure, and indirect prompt injection risk. These findings go beyond what a conventional supplier assessment would normally surface and show that the framework translates AI-specific risk themes into assessable questions.

O2: Classification-driven proportionality. The framework should produce different assessment scopes for products with different risk profiles. The two illustrative scenarios confirm this. Miro AI was classified as Human-in-the-Loop with data sensitivity D2, resulting in 18 baseline questions. Claude CoWork was classified as Autonomous with data sensitivity D2, resulting in 31 questions across both tiers. Despite sharing the same data sensitivity level, the two products received meaningfully different assessments because the classification mechanism responded to the difference in operational autonomy. This demonstrates that the two-axis classification produces proportional assessment scopes without requiring the assessor to make a subjective judgement about

how thorough the assessment should be.

O3: ISO 27001 integration. The framework should function as a supplement to existing supplier assessment processes under ISO 27001 Annex A controls A.5.19–A.5.22, not as a standalone tool. This objective is validated primarily through the framework’s design rather than through the illustrative scenarios. The framework is structured as an additional step within an existing supplier evaluation workflow. It does not replace any existing controls or require the organisation to restructure its ISMS process. However, the framework has not been deployed within an actual ISMS, which means that practical integration challenges remain untested. Whether the framework introduces friction or fits naturally into existing workflows is a question that requires validation in a real procurement context.

O4: Practitioner accessibility. The framework should be usable by information security professionals who do not have expertise in machine learning or AI. Each question in the framework includes evaluation guidance that explains what the question investigates and what a satisfactory answer looks like. The illustrative scenarios were conducted using this guidance, which provides indirect evidence that the assessment can be carried out without requiring the assessor to independently interpret AI-specific technical concepts. However, this objective has not been validated through user testing with practitioners. Whether the evaluation guidance is sufficient for a practitioner without an AI background to complete an assessment remains an open question.

5.4 Limitations of the Scenario-Based Evaluation

While the illustrative scenarios successfully demonstrate the mechanical feasibility and risk coverage of the framework, it is necessary to acknowledge the methodological limitations of researcher-led evaluations. Because the scenarios were conducted by the authors of the framework, who possess specialized knowledge of both the instrument and AI security concepts, the scenarios cannot objectively validate the method’s usability or accessibility for the intended target audience of non-AI-specialist procurement officers. Furthermore, the selection of the two extreme scenarios (Miro and CoWork) demonstrates the framework’s tiering logic in idealised conditions. To definitively prove the framework’s accessibility (O4) and its ability to consistently prevent assessment fatigue across a broad portfolio of software (O2), future research must involve empirical evaluations where standard information security specialists apply the framework to real-world procurements.

6 Discussion

The following chapter discusses the research questions, limitations, and ethical and societal aspects.

6.1 Research questions

Based on the results presented in Chapter 4 and Chapter 5, we can draw several conclusions related to our research questions presented in Section 1.2.

6.1.1 Research Question 1

Research Question 1 asks what AI-specific information security risks should be addressed when evaluating AI products. Answering this question involved three stages.

The first stage identified relevant information security risks associated with procured AI products. These risks were presented in section 2.4, and a general conclusion is that many information security risks are more or less connected to each individual CIA property. From a technical perspective, the AI risks can instead be grouped into different categories, such as supply chain risks, model training ambiguities, or agentic capabilities. As this thesis is grounded in information security, the CIA division of risks made more sense for the final framework even though a technical grouping would have made the connection to specific AI architectures more explicit. It would also have required the assessor to understand those architectures, which conflicts with the design constraint of practitioner accessibility (O4).

The second stage translated the found risks into requirements and questions to help mitigate mentioned risks. This stage involved many iterations and is at the core of what the final framework later became. The risks are many and multifaceted, and questions devised in this stage are part of what mitigates and investigates them. Early versions of the question batteries were tested against the illustrative scenarios, which revealed questions that could be left with a vague answer, questions that overlapped, and risk areas where no question existed. As a practical example, the OWASP Top 10 for Agentic Security was used to validate coverage of agentic risks, which led to additions to the deeper diligence battery.

The final stage examined whether the questions developed in the second stage could surface AI-specific risks when applied to real AI products. For instance, the Miro assessment confirmed that the baseline battery identifies supply chain opacity and absent

model change notifications. The CoWork assessment confirmed that the deeper diligence battery identifies and questions credential inheritance and persistent context risk. Several deeper diligence questions could not be fully answered from public documentation alone, which is itself a finding that indicates where the assessor would need to engage the vendor directly.

6.1.2 Research Question 2

Research Question 2 asks how AI products can be classified to enable proportional security assessments. As argued in section 2.3.1, classification is necessary to assess products appropriately. Avoiding unnecessary burden on low-risk vendors while ensuring sufficient scrutiny of high-risk products can simplify the process for both the procuring organisation and the vendor organisation.

Regarding the assessment scrutiny levels, conventional supplier assessment processes determines scrutiny based on what data the supplier processes. This makes sense, since data and information classification is a central aspect of traditional information security assessments. This thesis argues that for AI products a second dimension is needed, what the system can do without human intervention. This is because two AI products processing identical data can present fundamentally different risk profiles if one merely displays suggestions while the other autonomously executes actions across connected systems. With more autonomous and agentic systems it is also more difficult to specify and isolate which data and information the system will process. A classification that accounts for both dimensions enables proportional assessment, ensuring that high-risk products receive the scrutiny they require while low-risk products are not burdened with unnecessary assessments.

The final framework handles this principle through a two-axis classification. Operational autonomy is defined across three levels (Advisory, Human-in-the-Loop, Autonomous) and data sensitivity across four levels (D1-D4), combined through a highest watermark principle to produce a Baseline or Deeper diligence assessment tier. The illustrative scenarios in Chapter 5 demonstrated that this mechanism produces meaningfully different outcomes: Miro AI (HITL, D2) received 18 questions while Claude CoWork (Autonomous, D2) received 31, despite sharing the same data sensitivity. The results show that AI products can be classified for proportional assessment by combining operational autonomy with data sensitivity. This two-axis classification produces different assessment scopes for products with different risk profiles without requiring the assessor to make a subjective judgement about how much scrutiny is appropriate.

6.2 Limitations

The framework developed in this thesis has limitations that should be considered when interpreting the results.

The first aspect is that AI research and breakthroughs are ongoing, and this work is based on our best efforts given the current landscape. If the underlying technology changes substantially, parts of the framework, particularly the deeper diligence battery, would need revision. This is because the two-tiered structure of the framework keeps the baseline questions general enough to mitigate this risk, whereas the deeper diligence section is required to treat risks with the current AI and LLM architecture.

Furthermore, the framework has not been used in a real procurement process. The illustrative scenarios demonstrate that the framework can be applied to real products and that it surfaces findings, but they do not confirm that the framework changes how organisations make procurement decisions. A real deployment would involve direct dialogue with the vendor and organisational constraints that the scenarios do not capture. The evaluation also relies on two illustrative scenarios, both involving SaaS products from the collaboration and productivity domain. While the two products were purposively selected to contrast on the autonomy axis, two cases are not sufficient to claim that the framework performs equally well across all categories. AI products in regulated industries or products from vendors outside the Western market can present risks that the current scenarios do not cover. Both scenarios were also assessed using only publicly available vendor documentation. As mentioned, in a real assessment, the assessor would conduct direct dialogue with the vendor. Several deeper diligence questions could not be fully answered for this reason, which means the deeper diligence tier is less tested than the baseline tier.

Regarding the tiers of autonomy, the framework’s classification is based on the product’s technical capabilities rather than how users actually interact with it. Human-in-the-Loop systems are classified alongside Advisory on the basis that the system structurally requires human approval before acting. In practice, research on automation bias and alert fatigue suggests that human oversight degrades over time, particularly when approval becomes routine [50]. A system that technically requires confirmation but presents suggestions that are accepted without scrutiny may, in practice, behave closer to an Autonomous system.

Finally, practitioner accessibility is a core design objective of the framework, but it has not been validated through user testing. The illustrative scenarios provide indirect evidence that the assessment can be conducted using the evaluation guidance, but they do not confirm that a practitioner without AI expertise would find the framework usable or efficient.

6.3 Ethical and societal aspects

Overall, we believe our work has a positive societal impact since it is built to inform information security professionals about risks with AI products today. It necessitates a kind of transparency that is seldom seen in practice and by default, since AI service providers tend to focus on potential benefits and the efficiency gains their products can provide, rather than the security implications for the procuring organisation. This could be considered a broader societal issue worth mentioning, the power asymmetry between AI vendors and procuring organisations. Vendors control what information they disclose publicly, and many of the risks identified in this thesis are only visible when the right questions are asked. Organisations without the resources or expertise to conduct structured assessments may adopt AI products without understanding the associated risks. By making the framework accessible to information security professionals who are not AI specialists, this thesis aims to reduce that asymmetry.

Finally, this thesis does not fully address the ethical dimensions of AI systems themselves, such as fairness, bias, or transparency of model decisions. These are important concerns but fall outside the scope of information security and are better addressed through standards such as ISO/IEC 42001. The framework is limited to assessing whether an AI product meets the organisation's information security requirements, not whether the AI itself behaves ethically.

7 Conclusions

The rapid integration of AI products has fundamentally challenged traditional information security risk management approaches. Conventional vendor assessment processes, such as those anchored in the ISO 27001 supplier controls, were designed to evaluate deterministic software. Because of this they fail to capture the vulnerabilities introduced by AI. To address this gap, this thesis developed a vendor assessment framework designed to extend traditional supplier assessments to evaluate AI products specifically.

A core finding of this thesis is that evaluating an AI product solely based on the sensitivity of the data it can access is insufficient. As demonstrated by the illustrative scenarios, two products processing the exact same classification of data can present different security threats based on their technical capabilities. This highlights the primary contribution of this research, a structural shift away from traditional, data-centric risk evaluation to now also include the product's operational autonomy. By evaluating the products based on their autonomy alongside the data sensitivity, the framework proves that an AI system's risk is dictated just as much by what the system is permitted to do as by what data it can access. This two-axis classification also enables proportional assessments. By separating the framework into baseline and deeper diligence tiers, it ensures that low-risk tools are not over-assessed, ultimately reducing the issue of assessment fatigue.

The significance of this framework lies in its practical use for information security professionals. By translating AI vulnerabilities into specific questions accompanied by evaluation guidelines, such as the "What a good answer looks like" and "Why it matters" columns, the framework bridges a severe industry knowledge gap. It empowers information security professionals to confidently assess AI vendors and guides them to reach an informed procurement decision without requiring deep AI knowledge.

7.1 Future Work

While the framework developed in this thesis provides a strong structural foundation for assessing AI products, the rapid development of artificial intelligence and the complexity of procurement processes require further research.

One significant limitation of this research is that the framework was evaluated analytically through illustrative scenarios conducted by the authors. While these scenarios showed that the framework successfully captures the necessary security risks, its actual usability in practice remains untested. Future research should deploy the framework in real-world procurement processes, conducting user testing with information security

professionals. This testing is required to evaluate if the guidelines are clear and easy to follow, and to refine the phrasing of the questions to ensure that they are fully accessible to practitioners without AI expertise.

Future versions of the framework could also expand the assessment criteria for HITL products by targeting the robustness of the human approval mechanism. Currently, the framework relies on human intervention to prevent autonomous execution. However, it does not evaluate the quality of that human intervention. Future work should introduce questions to assess whether a product actively mitigates automation bias. For example, the assessment could investigate whether the system enforces deliberate confirmation rather than one-click approval, or whether it logs approval response times to detect habitual approval behaviour. Evaluating these approval mechanisms will ensure that the HITL guardrails function as intended rather than becoming automated processes.

A final area for future research concerns the lack of structured decision making guidance. While the current framework surfaces AI-specific vulnerabilities, it leaves the ultimate risk acceptance decision entirely to the assessor. Future iterations should explore how to translate these qualitative findings into a concrete procurement decision. Specifically, research could investigate the development of a risk-scoring model or an evaluation system that assists practitioners in reaching a standardized, defensible conclusion, such as a definitive "pass, fail, or approved with conditions".

References

- [1] D. Ah-king, “Ai vendor security and safety assessment guide,” <https://storage.ghost.io/c/44/95/449506ca-034e-480f-9725-fcde08ef1cc1/content/files/2025/04/AI-Vendor-Security-and-Safety-Assessment-Guide-1.01.pdf>, Apr. 2025, licensed under Creative Commons Attribution-NonCommercial-ShareAlike 4.0 International. Accessed 3 March 2026.
- [2] Anthropic. (2025) Updates to consumer terms and privacy policy. [Online]. Available: <https://www.anthropic.com/news/updates-to-our-consumer-terms>
- [3] Anthropic. (2026) Coordinated vulnerability disclosure. Anthropic. [Online]. Available: <https://www.anthropic.com/coordinated-vulnerability-disclosure>
- [4] Anthropic. (2026) Get started with cowork. Anthropic. [Online]. Available: <https://support.claude.com/en/articles/13345190-get-started-with-cowork>
- [5] Anthropic. (2026) Use cowork safely. Anthropic. [Online]. Available: <https://support.claude.com/en/articles/13364135-use-cowork-safely>
- [6] E. Bergström, F. Karlsson, and R.-M. Åhlfeldt, “Developing an information classification method,” *Information and Computer Security*, vol. 29, no. 2, pp. 209–239, 2021.
- [7] N. Carlini, F. Tramèr, A. Herbert-Voss, D. Song, K. Lee, Ú. Erlingsson, E. Wallace, A. Roberts, A. Oprea, M. Jagielski, T. Brown, and C. Raffel, “Extracting training data from large language models,” 2021. [Online]. Available: <https://arxiv.org/abs/2012.07805>
- [8] M. Christodorescu, E. Fernandes, A. Hooda, S. Jha, J. Rehberger, and K. Shams, “Systems security foundations for agentic computing,” *Cryptology ePrint Archive*, Paper 2025/2173, 2025. [Online]. Available: <https://eprint.iacr.org/2025/2173>
- [9] J. Cobbe, M. Veale, and J. Singh, “Understanding accountability in algorithmic supply chains,” in *Proceedings of the 2023 ACM Conference on Fairness, Accountability, and Transparency (FAccT ’23)*. New York, NY, USA: Association for Computing Machinery, 2023. [Online]. Available: <https://doi.org/10.1145/3593013.3594073>
- [10] Data & Trusted AI Alliance, “About — the data & trusted ai alliance,” 2025, accessed: 2026-03-02. [Online]. Available: <https://www.dtaalliance.org/about>

-
- [11] European Parliament and Council of the European Union, “Regulation (eu) 2024/1689 of the european parliament and of the council laying down harmonised rules on artificial intelligence (artificial intelligence act),” 2024, article 3(1).
- [12] European Union, “Regulation (eu) 2016/679 of the european parliament and of the council of 27 april 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing directive 95/46/ec (general data protection regulation),” *Official Journal of the European Union*, L 119, pp. 1–88, Apr. 2016. [Online]. Available: <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
- [13] European Union, “Regulation (eu) 2024/1689 (artificial intelligence act),” 2024, accessed 2026-04-08. [Online]. Available: <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng>
- [14] FS-ISAC, “Generative AI vendor risk assessment guide,” Feb. 2024. [Online]. Available: https://www.fsisac.com/hubfs/Knowledge/AI/FSISAC_GenerativeAI-VendorEvaluation&QualitativeRiskAssessment.pdf
- [15] GeeksforGeeks. (2024) Information classification in information security. [Online]. Available: <https://www.geeksforgeeks.org/blogs/information-classification-in-information-security/>
- [16] A. R. Hevner, S. T. March, J. Park, and S. Ram, “Design science in information systems research 1,” *Tech. Rep.*, 2004.
- [17] V. Q. Hoang, V. La, H. Nguyen, and M. Nguyen, “Some discussions on critical information security issues in the artificial intelligence era,” *AI and Society*, vol. 40, no. 4, pp. 2651–2661, 2025.
- [18] IBM. (2025) AI agents in 2025: Expectations vs. reality. [Online]. Available: <https://www.ibm.com/think/insights/ai-agents-2025-expectations-vs-reality>
- [19] IBM. (2025) What is generative AI? [Online]. Available: <https://www.ibm.com/think/topics/generative-ai>
- [20] International Association of Privacy Professionals (IAPP). (2024) Beyond gdpr: Unauthorized reidentification and the mosaic effect in the eu ai act. [Online]. Available: <https://iapp.org/news/a/beyond-gdpr-unauthorized-reidentification-and-the-mosaic-effect-in-the-eu-ai-act>
- [21] International Organization for Standardization, *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection – Information security management systems – Requirements*, ISO Std., 2022.

- [22] International Organization for Standardization, *ISO/IEC 27002:2022 Information security, cybersecurity and privacy protection – Information security controls*, ISO Std., 2022.
- [23] International Organization for Standardization, “The iso survey of management system standard certifications,” 2023, includes statistics on ISO/IEC 27001 certifications worldwide.
- [24] International Organization for Standardization, *ISO/IEC 42001:2023 Information technology Artificial intelligence Management system*, Std., 2023.
- [25] J. King, K. Klyman, E. Capstick, T. Saade, and V. Hsieh, “User privacy and large language models: An analysis of frontier developers’ privacy policies,” arXiv preprint arXiv:2509.05382, 9 2025. [Online]. Available: <https://arxiv.org/abs/2509.05382>
- [26] Miro. (2024) Customer data processing addendum. [Online]. Available: <https://miro.com/legal/customer-data-processing-addendum/>
- [27] Miro. (2025) AI terms. [Online]. Available: <https://miro.com/legal/ai-features-addendum/>
- [28] Miro. (2025) Enterprise security. [Online]. Available: <https://miro.com/enterprise-security/>
- [29] Miro. (2025) Miro AI admin security. [Online]. Available: <https://help.miro.com/hc/en-us/articles/28765406244498-Miro-AI-overview>
- [30] Miro. (2025) Privacy policy. [Online]. Available: <https://miro.com/legal/privacy-policy/>
- [31] Miro. (2026) AI trust capabilities and FAQs. [Online]. Available: <https://help.miro.com/hc/en-us/articles/30943405198994-AI-Trust-Capabilities-and-FAQs>
- [32] Miro. (2026) Current subprocessors list. [Online]. Available: <https://miro.com/legal/current-subprocessors-list/>
- [33] Miro. (2026) Enterprise guard and microsoft purview DSPM for AI integration overview. [Online]. Available: <https://help.miro.com/hc/en-us/articles/28617278171154-Enterprise-Guard-and-Microsoft-Purview-DSPM-for-AI-Integration-Overview>
- [34] Miro, “Miro ai credits,” 2026, accessed: 2026-03-09. [Online]. Available: <https://help.miro.com/hc/en-us/articles/19756209116178-Miro-AI-credits>

-
- [35] Miro, “Miro ai credits for enterprise plans,” 2026, accessed: 2026-03-09. [Online]. Available: <https://help.miro.com/hc/en-us/articles/19973211245586-Miro-AI-Credits-for-Enterprise-Plans>
- [36] Miro. (2026) Miro AI granular admin controls. [Online]. Available: <https://help.miro.com/hc/en-us/articles/27016283682578-Miro-AI-granular-admin-controls>
- [37] Miro. (2026) Miro AI quality improvements. [Online]. Available: <https://help.miro.com/hc/en-us/articles/22874000865554-Miro-AI-quality-improvements>
- [38] Miro. (2026) Miro AI reference. [Online]. Available: <https://help.miro.com/hc/en-us/articles/20970362792210-Miro-AI-reference>
- [39] Miro, “Rate limiting,” 2026, accessed: 2026-03-09. [Online]. Available: <https://developers.miro.com/reference/rate-limiting>
- [40] Myndigheten för samhällsskydd och beredskap (MSB), “Klassning av information,” Web page, Metodstödet för systematiskt informationssäkerhetsarbete, 2024, published 20 June 2024. [Online]. Available: <https://metodstod-informationssakerhet.msb.se/sv/anvanda/klassning-av-information/>
- [41] National Institute of Standards and Technology, “Artificial Intelligence Risk Management Framework (AI RMF 1.0),” U.S. Department of Commerce, Washington, D.C., NIST AI 100-1, January 2023. [Online]. Available: <https://doi.org/10.6028/NIST.AI.100-1>
- [42] National Institute of Standards and Technology, “Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile,” U.S. Department of Commerce, NIST AI 600-1, July 2024, accessed 2026-04-08. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>
- [43] OECD, “OECD Framework for the Classification of AI Systems,” Paris, 2022. [Online]. Available: <https://doi.org/10.1787/cb6d9eca-en>
- [44] OWASP, “Llm and generative ai data security best practices,” Open Worldwide Application Security Project, Tech. Rep., 2025, accessed: 2026-02-26. [Online]. Available: <https://genai.owasp.org/resource/llm-and-gen-ai-data-security-best-practices/>
- [45] OWASP. (2025, Dec.) OWASP top 10 for agentic applications. [Online]. Available: <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications/>
- [46] OWASP. (2025, Nov.) OWASP top 10 for LLM applications 2025. [Online]. Available: <https://genai.owasp.org/owasp-top-10-for-llm-applications-2025/>

-
- [47] K. Peffers, M. Rothenberger, T. Tuunanen, and R. Vaezi, “Design science research evaluation,” in *Design Science Research in Information Systems: Advances in Theory and Practice — 7th International Conference, DESRIST 2012, Las Vegas, NV, USA, May 14–15, 2012, Proceedings*, ser. Lecture Notes in Computer Science, K. Peffers, M. Rothenberger, and B. Kuechler, Eds., vol. 7286. Berlin, Heidelberg: Springer, 2012, pp. 398–410.
- [48] K. Peffers, T. Tuunanen, M. A. Rothenberger, and S. Chatterjee, “A design science research methodology for information systems research,” *Journal of Management Information Systems*, vol. 24, pp. 45–77, 12 2007.
- [49] V. Ricuia, *LLMs at Work*. Apress, 2024. [Online]. Available: <https://vladris.com/llm-book/large-language-models.html>
- [50] G. Romeo and D. Conti, “Exploring automation bias in human–AI collaboration: A review and implications for explainable AI,” *AI & Society*, vol. 41, pp. 259–278, 2025, open access.
- [51] Stanford Institute for Human-Centered Artificial Intelligence, “Ai index report 2026,” Apr. 2026, accessed 2026-04-15. [Online]. Available: <https://hai.stanford.edu/ai-index/2026-ai-index-report>
- [52] K. Stine, R. Kissel, W. C. Barker, J. Fahlsing, and J. Gulick, “Guide for Mapping Types of Information and Information Systems to Security Categories,” National Institute of Standards and Technology, Gaithersburg, MD, NIST Special Publication (SP) 800-60 Vol. 1 Rev. 1, 2008.
- [53] Svenska institutet för standarder (SIS). (2026) Vad är informationssäkerhet? Accessed: 2026-01-29. [Online]. Available: <https://www.sis.se/iso27001/informationssakerhet/>
- [54] Z. Zhang, S. Cui, Y. Lu, J. Zhou, J. Yang, H. Wang, and M. Huang, “Agent-safetybench: Evaluating the safety of LLM agents,” *arXiv preprint arXiv:2412.14470*, 2024. [Online]. Available: <https://arxiv.org/abs/2412.14470>

A Assessment Framework Questionnaires

The following tables present the complete baseline and deeper diligence questionnaires developed for the AI vendor assessment framework.

Table 5: Baseline Assessment Tier

CIA	Question	Why it matters	What a good answer looks like
Confidentiality	Is the AI feature (if it is a feature) enabled by default, or must an admin activate it?	Default-on features can expose data to AI processing before any risk assessments has been completed. Many AI add-ons in SaaS products activate automatically on upgrade.	Opt-in and admin activation is preferred. Sometimes the AI feature is 'useless', or provide limited extra value.
	Can the AI feature (if it is a feature) be disabled for specific users, groups or data types?	Granular controls allow the organisation to limit AI exposure to users or sensitive data categories without disabling the product entirely.	Admin-level controls exist. Scoping by user group or data type confirmed.
	Is organisational input data used to train or improve the vendor's AI model? Is there a contractual clause explicitly prohibiting use of organisational data for model training or fine-tuning?	Training use is an irreversible data transfer. Once embedded in model weights, data cannot be extracted or deleted. Risks are that our data leaks to other users.	Explicit 'no' confirmed in writing. If yes or unclear, escalate to deeper diligence.
	Does the vendor store or log input data on their infrastructure? Does the vendor provide audit rights to independently verify data handling claims	Any data stored outside our environment is not in direct control. Storage creates a persistent exposure.	A clearly defined and short retention period with documented purpose. Zero retention also possible but makes logging less effective.
	Can data processed by the AI system be deleted on request, and are retention periods contractually defined (ISO 27001 A.8.10)?	If data was used for model training, it becomes part of the model weights and cannot be extracted or deleted, unlike any other SaaS data. This question is about confirming the vendor deletes the prompt as well.	Vendor confirms whether deletion is technically possible. If no training: retention periods defined in contract - then deletion. If training has occurred and deletion is impossible, residual risk formally accepted with management sign-off.

Continued on next page

Table 5 – continued from previous page

CIA	Question	Why it matters	What a good answer looks like
Integrity	Do vendor personnel review, access, or monitor customer prompts, inputs, or outputs for quality assurance, safety monitoring, or any other purpose? If yes, what controls govern this access?	A vendor might not train on the data but still have human reviewers reading prompts for content moderation or safety monitoring.	No human review of customer data, or: human review exists with documented access controls, NDA, purpose limitation, and audit trail. Customer notified of review scope.
	What data is included in the prompt sent to the model? full documents, excerpts, or metadata only?	AI systems often send far more context than the user intends. A feature that summarises one email may silently send the entire inbox thread, or attach user profile data. The amount of data sent determines the actual confidentiality exposure.	Vendor documents precisely what is included in the model context. Data minimisation is applied by design.
	Does the AI functionality access data beyond what is strictly needed (e.g. full mailbox vs. current email only)?	AI tools are often granted broad access to the host product's data to function. Can silently elevate the effective data classification of what the vendor processes.	Least privilege applied. Feature data access scoped to minimum required. Admin can restrict scope.
	Does the vendor provide audit logs covering both what data was sent to the model and what output was produced, including any action taken?	Without logs you cannot investigate a suspected data exposure or demonstrate compliance. Equivalent to access logging in ISO 27001 A.8.15.	Logs available to customer admin. Include timestamp, user, data scope. Exportable. Retained minimum x days.
	Is the vendor aware of limitations of the AI system, if yes what are those.	Unlike normal software bugs, AI failures produce plausible-sounding incorrect outputs with no error signal. Users need to know when not to trust the output.	Public documentation of limitations exists. Known error categories documented.

Continued on next page

Table 5 – continued from previous page

CIA	Question	Why it matters	What a good answer looks like
Availability	Is the AI output deterministic (same input = same output) or probabilistic (output varies)?	Probabilistic outputs mean the same process run twice may produce different results, which affects reproducibility, auditability, and user trust. This is not inherently wrong but it leads to difficulties reproducing errors when trying to diagnose an issue.	Behaviour documented. If probabilistic, end users are informed and outputs are not used where reproducibility is required.
	Can AI-generated content be distinguished from human-created content within the product?	When AI output and human output coexist in the same workspace, the origin of content becomes ambiguous. Without attribution, the organisation cannot assess the reliability of specific content, cannot trace errors back to their source, and may unknowingly present AI-generated output as verified human work.	AI-generated content is visually or programmatically distinguishable from human-created content. The marking persists even after the content is edited. A product where AI-generated content becomes indistinguishable the moment it appears provides no auditability of content origin.
	Is the AI-service dependent on an external API or cloud service?	Hidden external dependencies mean a third-party outage can affect your product without warning. Many AI-services call external model APIs that are not covered by the main vendor's SLA.	All external dependencies disclosed. Ideally the vendor is not dependant on a third-party for the AI-model
	(if the AI is a feature) Does an AI failure or outage affect core non-AI product functionality?	If AI and core functionality share infrastructure, an AI-related incident can take down the whole product. These should be independently deployable.	Core functionality remains fully available if AI component fails.

Continued on next page

Table 5 – continued from previous page

CIA	Question	Why it matters	What a good answer looks like
General	Does the vendor impose usage limitations, rate limits, or throttling mechanisms that could restrict the organisation's access to AI functionality, and what happens when these limits are reached?	AI products commonly enforce usage caps, token limits, cooldown periods, or rate limiting that can interrupt access to core functionality. Unlike traditional SaaS, where the service is either available or not, AI products can degrade gradually through throttled response times, reduced model quality, or temporary lockouts. This question examines whether the organisation can anticipate and plan for such restrictions.	The vendor clearly documents all usage limits and the conditions under which they apply. The organisation is notified before limits are reached. When limits are reached, the behaviour is predictable, such as queuing requests, offering paid overage. The vendor provides advance notice before changing usage terms.
	Which sub-processors handle the data and in which geographical regions?	AI products routinely chain multiple cloud providers. The vendor you contract with may hand data to a model provider (e.g. OpenAI, Anthropic, Google) who may process it in a different jurisdiction under different legal obligations.	Full sub-processor list published and kept current. Processing regions confirmed. Ideally the regions are required
	Have you classified this system under legal or regulatory frameworks (e.g., EU AI Act, NIST, HIPAA)?	A vendor that has not considered the regulatory landscape for their own product may lack basic governance maturity. Their classification also affects your organisation's obligations as a deployer under frameworks like the EU AI Act.	Classification has been completed under relevant frameworks. e.g. risk category from the EU AI Act.

Continued on next page

Table 5 – continued from previous page

CIA	Question	Why it matters	What a good answer looks like
	Has an information security risk assessment been completed for this AI system before deployment (ISO 27001 Cl. 6.1)?	A general vendor risk assessment covers the vendor relationship. This question sheet is mainly focused on AI-specific issues and assumes a general ISRA has been completed beforehand.	Risk assessment documented, approved by asset owner, and on file before go-live. Reviewed on significant change or annually.

Table 6: Deeper Diligence Assessment Tier

CIA	Question	Why it matters	What a good answer looks like
Confidentiality	What tools does the AI system have access to, and what is the permission scope of each (file systems, databases, APIs, messaging)?	Tool access is the agent's attack surface. Each tool is a potential path for data exfiltration, unauthorised action, or lateral movement. Equivalent to access control review in ISO 27001 A.8.2. See Owasp top 10 for Agents: ASI02: Tool Misuse and Exploitation	Full tool inventory documented. Each tool has defined, minimal permission scope. Admin can restrict or disable individual tools. Least Agency and Least Privilege for tools.
	How are privacy and security risks reassessed when the model is updated, retrained, or fine-tuned?	A model update could change what the model has memorised, how it handles sensitive inputs, or what data it exposes in outputs. Your re-assessment triggers define when you reassess the vendor — this asks whether the vendor reassesses their own privacy and security posture after retraining. Connects your external triggers to the vendor's internal governance.	Formal privacy/security review required before any model update goes to production. Review covers: new training data sources, changed memorisation risk, altered behaviour on sensitive inputs. Documentation available.
	Does the system maintain memory or context across sessions? How is this managed, inspected and cleared?	Persistent memory means data from previous sessions, including sensitive information shared by users, can influence future sessions. This creates a data retention risk that does not exist in stateless systems.	Memory scope documented. Customer can inspect and clear memory at any time. No persistent memory by default.

Continued on next page

Table 6 – continued from previous page

CIA	Question	Why it matters	What a good answer looks like
Integrity	How is IAM for agents deployed? What credentials, tokens, or permissions does the AI system operate with, and does it run under the end user's identity, a shared service account, or its own dedicated identity?	Covers ASI03 Identity and Privilege Abuse. A system that inherits the end user's full session credentials can do anything the user can do, which may far exceed what the task requires.	The vendor should clearly state the identity model and a good answer is a dedicated, scoped identity with only the permissions needed for the specific task. Can we define or restrict the permissions assigned to the AI system's identity. If the vendor cannot clearly explain the identity model, the organisation has no way to assess the blast radius of a credential compromise.
	Is cross-user or cross-tenant data leakage possible? Can one user's data appear in another's session?	Shared AI infrastructure can cause context from one user's session to appear in another's, a data breach with no traditional attack involved.	Vendor confirms session and tenant isolation by design. Architecture documentation available.
	What monitoring exists to detect model drift and silent behaviour change after a vendor model update?	Model drift means outputs change without any code or configuration change on your side. A security control that relied on the AI behaving consistently (e.g. always flagging certain content) may silently stop working. Notification focus is Tier 2; this question covers technical detection.	Vendor runs regression tests before updates. Changelog of behaviour differences published. Customer can validate against own test cases before update goes live.

Continued on next page

Table 6 – continued from previous page

CIA	Question	Why it matters	What a good answer looks like
	Is there end-to-end traceability? reasoning, tool calls, and outputs per session? What happens if the system fails partway through an action chain	An agent can take dozens of actions in a single session. Without a complete trace, a security incident cannot be investigated, and an erroneous action chain cannot be identified and corrected. Equivalent to activity logging under ISO 27001 A.8.15. Second question could be prevention of Cascading failures - ASI08.	Full log of reasoning steps, tool calls, inputs/outputs, user ID and timestamp. Exportable and tamper-evident.
	Are transaction limits or guardrails in place preventing irreversible or high-impact actions without explicit confirmation?	An agent that can take irreversible actions (send emails, delete records, make payments) without per-action confirmation has an unbounded blast radius. A single erroneous decision or injected instruction can cause large-scale damage.	Hard limits configured and enforced (e.g. max transaction value, max messages sent per hour). Actions above threshold escalate to human confirmation.
	Is the system protected against indirect prompt injection via tool outputs?	Prompt injection is the AI equivalent of SQL injection. An attacker embeds instructions inside content the agent reads (a document, a web page, a database record) that override the agent's intended instructions and cause it to take unauthorised actions.	input sanitisation, strict instruction hierarchy (system prompt cannot be overridden by user or tool content), sandboxed tool execution. See OWASP TOP 10 for Agentic Apps (ASI01 - Agent Goal Hijack prevention methods)

Continued on next page

Table 6 – continued from previous page

CIA	Question	Why it matters	What a good answer looks like
	If the system retains memory or context across sessions, what controls prevent stored information from being modified or corrupted through user inputs or external content?	the concern is that an attacker could craft inputs during normal use that get written into the system's persistent memory or retrieval database, then influence future outputs for the same or other users. This is covered in ASI06 - Memory & Context Poisoning, and builds on LLM04 Data and Model Poisoning, and LLM08 Vector and Embedding Weaknesses	Explain whether user inputs can directly modify stored context, whether memory entries are validated before storage, and whether the organisation can review or clear the system's accumulated context. A system with no integrity controls on its memory store means a single poisoned interaction could compromise all subsequent outputs.
	What mechanisms exist to prevent incorrect AI outputs from resulting in automated actions, and when errors do occur, how are affected records identified and corrected?	Autonomous AI systems can produce incorrect outputs, whether through hallucination in generative systems or misclassification in decision systems, that take effect without human review. The nature of the safeguard depends on the type of system, but the principle is the same: something must exist between the model's output and the executed action that reduces the likelihood or impact of errors.	For systems that generate free-text outputs, look for grounding mechanisms, confidence thresholds that gate execution, or automatic escalation to a human when confidence is low. For systems that classify or make structured decisions, look for accuracy monitoring, threshold configuration, edge-case escalation rules, and periodic revalidation against ground truth. For any autonomous system, look for ongoing quality monitoring — does the vendor track output accuracy over time and alert when performance degrades? A vendor that offers no mechanism between model output and executed action, regardless of product type, is insufficient.

Continued on next page

Table 6 – continued from previous page

CIA	Question	Why it matters	What a good answer looks like
Availability	Are AI components explicitly covered by the vendor's SLA, and what are the specific uptime commitments, RTO, RPO, and remedies for the AI service?	SLAs frequently cover the base product but exclude AI add-ons, which may be dependant on a third party hosting the AI model.	AI service explicitly named in SLA with defined uptime % and remedy for breach.
General	What is the incident response process for AI-specific security incidents across all three CIA dimensions? can we see an example/redacted incident report?	AI incidents span all CIA dimensions: a prompt leak is Confidentiality, corrupted model output is Integrity, a service outage is Availability. A generic IT incident process may not categorise or escalate AI incidents correctly. Vendor must have AI-specific incident categories and response procedures.	AI-specific incident categories defined covering C, I and A scenarios. Notification SLA contractually defined (e.g. within 24h of detection). Named security contact. Post-incident review process documented.

B Miro - Baseline Assessment

This appendix presents the complete baseline assessment of Miro as conducted in Chapter 5.1. The product was classified as Human-in-the-Loop in regards to autonomy level with D2 (Internal) data sensitivity, placing it in the Baseline assessment tier. All baseline questions were applied. All information is derived from publicly available documentation accessed in March 2026. Sources are cited per finding.

Table 7: Complete baseline assessment of Miro AI.

#	CIA	Question	Finding
B.1	C	Is the AI feature enabled by default, or must an admin activate it?	Admins can enable or disable Miro AI at the organisational level [29]. The exact default state for new enterprise deployments is not confirmed in public documentation. If enabled by default, employees may use AI features before the organisation has completed its assessment.
B.2	C	Can the AI feature be disabled for specific users, groups, or data types?	Miro's Intelligent Guardrails can automatically block AI usage on boards based on their content classification level. Boards classified as Confidential can have AI features disabled automatically while Internal boards retain access [36]. Whether AI can additionally be scoped by user group is not documented publicly. The restriction follows the data regardless of which user accesses the board.
B.3	C	Is organisational input data used to train or improve the vendor's AI model? Is there a contractual clause explicitly prohibiting this?	Miro states that customer data is not used to train AI models [29]. For enterprise customers, explicit consent is required before any use of input or output for AI improvement [27]. AI interactions are not shared with third-party model providers for training [37]. The no-training commitment is stated across multiple documents. Note: Free Plan users' interaction data may be collected for improvement unless the admin disables it [37]. Organisations with mixed plan types should verify coverage.

Continued on next page.

Table 7 continued from previous page.

#	CIA	Question	Finding
B.4	C	Does the vendor store or log input data on their infrastructure? Does the vendor provide audit rights to independently verify data handling claims?	Data submitted through Miro AI is stated to be used solely to generate a response [29]. The sub-processor (Azure OpenAI) reportedly does not retain data after processing [29]. Whether Miro itself logs AI interactions for enterprise customers, for how long, and with what access controls is not specified in public documentation. SOC 2 Type II and ISO 27001 certifications provide indirect assurance through third-party audit [28].
B.5	C	Can data processed by the AI system be deleted on request, and are retention periods contractually defined (ISO 27001 A.8.10)?	Board content deletion is governed by the Enterprise Guard content lifecycle management feature and the DPA [26]. The upstream model provider does not retain data after processing [29]. Whether AI-specific data — prompts, generated outputs, interaction metadata — is included in data deletion requests under the DPA is not documented in publicly available materials.
B.6	C	Do vendor personnel review, access, or monitor customer prompts, inputs, or outputs? If yes, what controls govern this access?	Customer-side monitoring is available through the Microsoft Purview integration, which forwards prompts and responses to the customer's own governance infrastructure [33]. Automated content moderation exists with configurable filtering levels [31]. The public documentation does not explicitly state whether Miro personnel can access, review, or monitor customer AI interactions. For Free Plan users, anonymised interaction data is collected for AI improvement [37], suggesting some form of data access occurs at that tier.

Continued on next page.

Table 7 continued from previous page.

#	CIA	Question	Finding
B.7	C	What data is included in the prompt sent to the model? Full documents, excerpts, or metadata only?	AI input consists of prompts entered by the user and content explicitly selected as context on the board [37]. No board content beyond what is directly involved in the AI process is collected [37]. The user controls the input boundary: if three sticky notes are selected, only those three are sent [29]. Scope depends on user behaviour — a user selecting an entire board as context sends everything on it.
B.8	C	Does the AI functionality access data beyond what is strictly needed?	The AI feature processes only user-selected content and cannot access the full board, other boards, or connected integrations beyond what the user explicitly includes [37, 29]. The assessor should verify whether newer features such as Sidekicks or Flows, which are described as more persistent AI agents, maintain the same scoping model [29].
B.9	C	Does the vendor provide audit logs covering what data was sent to the model and what output was produced?	For Enterprise Guard customers with the Microsoft Purview integration, full prompt and response logging is available, forwarded to the customer's own Purview tenant for review [33]. Governance, retention, and access controls over this data are managed in the customer's Microsoft environment. This requires both the Enterprise Guard add-on and a Microsoft Purview licence. For organisations without this configuration, the availability of AI-specific audit logs is not publicly documented.

Continued on next page.

Table 7 continued from previous page.

#	CIA	Question	Finding
B.10 I		Is the vendor aware of limitations of the AI system? Are there any measures implemented?	Miro explicitly acknowledges that AI outputs may be inaccurate and that output should always be checked before use [29]. The AI terms state that Miro does not guarantee outputs to be accurate, complete, or current, and places verification responsibility on the customer [27]. Input-side controls exist through AI moderation with configurable filtering levels [31]. No output-side safeguards against hallucination (e.g., grounding, confidence scoring) are documented in publicly available materials.
B.11 I		Is the AI output deterministic (same input = same output) or probabilistic (output varies)?	The underlying models (GPT-4o, Claude 3.7) are large language models, which are inherently probabilistic [38]. The AI terms acknowledge that outputs may be similar or identical to those provided to other customers, implying non-determinism [27]. Miro does not explicitly state that outputs are probabilistic or explain to end users what this means in practical terms.
B.12 I		Can AI-generated content be distinguished from human-created content within the product?	Miro's AI principles reference transparency and attribution. In practice, AI-generated content (sticky notes, diagrams, summaries) placed on a board appears visually identical to manually created content. Whether metadata distinguishing AI-generated from human-created content is retained and accessible to administrators is not confirmed in public documentation. Once AI output is placed on the canvas and edited, its origin becomes untraceable without such metadata.

Continued on next page.

Table 7 continued from previous page.

#	CIA	Question	Finding
B.13 A		Is the AI service dependent on an external API or cloud service?	Yes. Miro depends on multiple third-party model providers for AI functionality: Microsoft Azure OpenAI, Anthropic (both directly and via AWS Bedrock), Google, and StabilityAI. AWS provides the general hosting infrastructure. All dependencies are documented in the published sub-processor list [32]. For customers procuring through AWS Marketplace, all models are hosted on AWS Bedrock [38].
B.14 A		Does an AI failure or outage affect core non-AI product functionality?	The Miro AI overview describes AI as an additive set of features accessed through specific menus and context actions [29]. This suggests architectural separation, but whether a third-party API timeout or AI processing failure could degrade or freeze the core canvas functionality is not confirmed in public documentation.

Continued on next page.

Table 7 continued from previous page.

#	CIA	Question	Finding
B.15 A		Does the vendor impose usage limitations, rate limits, or throttling mechanisms that could restrict the organisation's access to AI functionality, and what happens when these limits are reached?	Yes. Miro uses a credit-based system where each AI action consumes credits from a monthly allocation. Credit allowances vary by plan: Free plans receive 10 credits per team per month, Starter 25 per licence, and Business 50 per licence [34]. Enterprise plans operate under a soft limit, meaning usage beyond the allocation is permitted, but persistent overuse requires purchasing the Miro AI credit add-on [35]. When credits are exhausted, a modal informs the user and presents options, including the paid add-on. Credit costs per action are documented most actions consume 1 credit [34]. Unused credits do not carry over between billing cycles. For the REST API, rate limiting is applied per user per application using a credit-based tier system with HTTP headers indicating remaining credits and reset times [39]. The API rate limiting documentation states that limits are subject to change at any time without notice [39], which means the organisation cannot rely on current limits remaining stable.
B.16 G		Has the vendor classified this system under legal or regulatory frameworks (e.g., EU AI Act, NIST AI RMF)?	Miro complies with GDPR and CCPA and is a self-certified member of the EU-US Data Privacy Framework. Miro holds ISO/IEC 42001 certification for AI management systems [28]. No formal risk tier or classification under AI-specific regulatory frameworks such as the EU AI Act or the NIST AI Risk Management Framework is publicly documented.
B.17 G		Has an information security risk assessment been completed for this AI system before deployment (ISO 27001 Cl. 6.1)?	Miro does not publish internal risk assessments. ISO 27001, ISO 42001, and SOC 2 Type II certifications provide independently audited evidence that structured risk assessment processes are integrated into the product lifecycle, including AI features [28].

Continued on next page.

Table 7 continued from previous page.

#	CIA	Question	Finding
B.18	G	Which sub-processors handle the data and in which geographical regions?	A published sub-processor list identifies all AI model providers (Microsoft, Anthropic, Google, StabilityAI) with their hosting arrangements and applicable licence terms [32]. The AI reference page maps features to specific models [38]. All listed sub-processors are located in the United States. Data residency options exist for the core product (EU, US, AU), but whether AI processing respects the customer's selected data residency at the model provider level is not confirmed.

C Claude CoWork - Deeper Diligence Assessment

This appendix presents the deeper diligence assessment of Claude CoWork as conducted in Chapter 5.2. The product was classified as Autonomous with D2 (Internal) data sensitivity. The highest watermark principle escalates this to the Deeper diligence assessment tier due to the Autonomous autonomy level. The baseline battery was also applied but is not repeated here as the question set is identical to Appendix B. All information is derived from publicly available documentation accessed in March 2026. Claude CoWork is designated as a research preview at the time of assessment. Sources are cited per finding.

Table 8: Deeper diligence assessment of Claude CoWork.

#	CIA	Question	Finding
D.1	C	What tools does the AI system have access to, and what is the permission scope of each?	CoWork can access local files in folders the user explicitly grants, execute code and terminal commands within a virtual machine, browse the web through the Claude in Chrome extension, and connect to external services through MCP connectors and plugins including Google Drive, Slack, GitHub, DocuSign, and Salesforce [4]. The VM provides controlled file and network access: CoWork can only access or modify files within granted directories [5]. Within those boundaries, CoWork has full read, write, and delete permissions [5]. Enterprise administrators can enable or disable the MCP server for the entire organisation or specific teams [4]. Individual users control which folders and MCP connectors are active. The documentation warns that each plugin “can significantly expand Claude’s scope of action” and recommends sticking to verified extensions from the Claude Desktop directory [5]. Per-tool permission granularity within connected services (e.g., restricting Google Drive to read-only) is not documented for all connectors. The scoping model is folder-level for local files and service-level for cloud integrations, rather than action-level permission scoping within each service.
D.2	C	How are privacy and security risks reassessed when the model is updated, retrained, or fine-tuned?	Not documented publicly. Anthropic updates the models powering CoWork periodically. CoWork currently runs on Opus 4.5 or 4.6 depending on availability [4]. Whether a formal privacy or security review is conducted before updated models are deployed to CoWork is not addressed in any publicly available material. The consumer terms update from September 2025 addresses data training opt-in but not the vendor’s internal model update governance [2].

Table 8 continued from previous page.

#	CIA	Question	Finding
D.3	C/I	Does the system maintain memory or context across sessions? How is this managed, inspected, and cleared? What controls prevent stored information from being modified or corrupted?	CoWork does not retain conversational memory across sessions. The documentation explicitly states: “No memory across sessions: Claude does not retain memory from previous Cowork sessions” [4]. Each task starts from a blank slate, and there is no mechanism for the model to recall what was discussed or processed in a previous session. Folder instructions are project-specific context tied to a particular working directory. CoWork can update folder instructions on its own during a session [4]. If CoWork processes files containing sensitive information, it may write summaries, observations, or contextual notes into folder instructions to improve its performance on subsequent tasks. This content persists across sessions and is loaded automatically whenever the user starts a new session in that folder.

Table 8 continued from previous page.

#	CIA	Question	Finding
D.4	C	How is IAM for agents deployed? What credentials, tokens, or permissions does the AI system operate with?	CoWork operates under the individual user's identity. When connecting to external services via MCP, CoWork authenticates using the user's own OAuth credentials [4]. This means CoWork inherits the full permission scope of whatever the user has access to in each connected service. If the user has administrative access to a shared Google Drive or write access to a Slack workspace, CoWork operates with those same privileges. There is no documented mechanism for creating a dedicated, scoped identity for CoWork that is separate from and more restricted than the user's own credentials. For local file access, the VM sandbox provides a form of scoping: CoWork can only access explicitly granted folders regardless of what the user can access on the broader filesystem [5]. This scoping does not extend to connected cloud services. MCP permission configuration, including how often connectors require user confirmation, is controlled by the user and works the same way across Claude's different modes [4]. The practical implication is that the blast radius of a compromised CoWork session equals the full access scope of the authenticated user across all connected services, minus any MCP confirmation prompts the user has configured. For an enterprise deployment, a single user connecting CoWork to organisational tools creates an aggregated access surface that no individual tool was designed to expose to an autonomous agent.

Table 8 continued from previous page.

#	CIA	Question	Finding
D.5	C	Is cross-user or cross-tenant data leakage possible?	CoWork runs file operations and code execution locally on the user’s machine inside a virtual machine [5]. However, model inference happens on Anthropic’s cloud servers. When CoWork processes a task, the prompt, including any file contents or context the agent has read, is sent to Anthropic’s API for inference. This means the cross-tenant isolation question applies at the inference layer, just as it does for any cloud-hosted AI service. For commercial customers (Team, Enterprise), data sent to the API is not used for training [2]. API logs are retained for 7 days before automatic deletion, and enterprise customers can negotiate zero-data-retention agreements. Whether session isolation is maintained at the inference API level, meaning one user’s prompt cannot influence another user’s response, is not explicitly documented. Additionally, content from web pages visited through the Claude in Chrome extension is sent to the API as part of the inference context [5].

Table 8 continued from previous page.

#	CIA	Question	Finding
D.6	I	What monitoring exists to detect model drift and silent behaviour change after a vendor model update?	Not documented publicly for CoWork. Anthropic updates its models on an ongoing basis, and CoWork uses the latest available model [4]. The public documentation does not describe whether Anthropic runs regression tests specifically for agentic use cases before deploying model updates, whether a changelog of behavioural differences is published, or whether enterprise customers can validate against their own test cases before an update goes live. There is no documented mechanism for the customer to pin CoWork to a specific model version or to defer an update. This gap is more consequential for an autonomous product than for a conversational assistant. If an updated model interprets a task slightly differently, the behavioural change takes effect as autonomous actions rather than as text on a screen. The user may not notice the shift because the output is not a response they read but an action CoWork executes in the background.
D.7	I	Is there end-to-end traceability of reasoning, tool calls, and outputs per session? What happens if the system fails partway through an action chain?	Users can review past runs via the Scheduled page in the CoWork sidebar [5]. The documentation surfaces what Claude is doing during a session but warns that users “shouldn’t expect to validate every individual command” [5]. Whether full session logs (reasoning steps, all tool calls, inputs/outputs, timestamps) are exportable or available to enterprise administrators is not documented. What happens if a multi-step task crashes halfway through, whether partially completed actions are rolled back, and how the organisation identifies which actions were taken before failure is not addressed in public documentation.

Table 8 continued from previous page.

#	CIA	Question	Finding
D.8	I	Are transaction limits or guardrails in place preventing irreversible or high-impact actions without explicit confirmation?	CoWork enforces qualitative boundaries for specific high-risk categories. Deletion protection requires explicit user approval before permanently deleting files [5]. The default permission mode prompts for shell commands on new web domains. However, public documentation does not indicate the presence of configurable, quantitative transaction limits. There is no documented feature allowing administrators to enforce hard limits such as maximum number of files edited per hour, maximum Slack messages sent, or a cap on sequential autonomous actions before forcing a human review [5].
D.9	I	Is the system protected against indirect prompt injection via tool outputs?	CoWork mitigates web-based prompt injection through a per-domain permission system requiring explicit user approval before interacting with new websites, supported by admin-controlled blocklists for high-risk domains [5]. Anthropic explicitly acknowledges the broader risk: “We’ve built sophisticated defenses against prompt injections, but agent safety, that is, the task of securing Claude’s real-world actions, is still an active area of development in the industry” [5]. The VM sandbox contains the effects of a successful injection to within permitted folders and approved network endpoints. However, within those boundaries a successful injection could still cause CoWork to take unintended actions on permitted files or connected services, or write malicious content into persistent folder instructions.

Table 8 continued from previous page.

#	CIA	Question	Finding
D.10 I		What mechanisms exist to prevent incorrect AI outputs from resulting in automated actions, and when errors do occur, how are affected records identified and corrected?	Preventative mechanisms rely on hardcoded human-in-the-loop guardrails. CoWork pauses and requires explicit user approval before irreversible actions like deleting files [5]. For identifying and correcting errors, CoWork provides a local task history to review past runs, but it lacks a built-in automated rollback or undo function for file edits [5]. The documentation recommends keeping backups of important files, which is a manual precaution rather than a system-level recovery mechanism.
D.11 A		Are AI components explicitly covered by the vendor's SLA, and what are the specific uptime commitments, RTO, RPO, and remedies for the AI service?	No. CoWork is currently designated as a research preview. Anthropic explicitly excludes it from standard Enterprise SLAs, Business Associate Agreements, and uptime remedies that cover the standard Claude Chat interface [4].
D.12 G		What is the incident response process for AI-specific security incidents across all three CIA dimensions? Can we see an example or redacted incident report?	While Anthropic maintains a Vulnerability Disclosure Program and high-level enterprise security protocols, an incident response playbook specifically tailored to agentic AI failures (e.g., if CoWork autonomously deletes the wrong directory or sends sensitive data through a connected service) is not publicly published. Whether AI-specific incident categories exist covering confidentiality, integrity, and availability dimensions, and whether a notification SLA is contractually defined for agentic incidents, would need to be confirmed under commercial terms [3].